

ENTREGA PARCIAL



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

1. DESCRIÇÃO DO PROBLEMA E PERSONAS “IA-Augmented”

1.1 - Descrição do Problema, Solução e Oportunidade de IA:

- Problema (250 caracteres)
- Solução (250 caracteres)
- Identificar explicitamente onde a IA gera valor na solução do problema (automação, predição ou geração de conteúdo).
- Personas.

Problema

A Jotanunes pede os documentos das terceirizadas de forma manual, por e-mail e mensagens, sem um lugar único que mostre o que cada empresa enviou, o que falta, o que foi recusado e por quê, nem quem analisou.

Solução

Plataforma web em duas partes: a área Jotanunes (via Fluig ou login próprio) cadastra obras, empresas e documentos exigidos, convida por e-mail e analisa; no portal, a terceirizada entra com CNPJ e senha e envia os arquivos.

Onde a IA gera valor

Transparência: a versão atual do produto (API, área Jotanunes e portal) **não usa IA em produção** — não há chamada a modelo de linguagem, OCR nem modelo preditivo. A análise dos documentos é 100% humana. A IA gerou valor no **processo de construção** e há oportunidades claras de IA no produto, apresentadas abaixo como **proposta para a próxima iteração**.

Valor atual da IA no processo (usado de fato):

- **Transcrição dos requisitos (automação):** o áudio da conversa com o representante da Jotanunes (4 min 16 s) foi transcrito localmente com o *faster-whisper* (modelo "medium", gratuito, sem enviar o áudio a terceiros). Nomes próprios mal reconhecidos foram corrigidos à mão ("JET News" → Jotanunes, "fluido"/"WIG" → Fluig, "esse IPJ" → CNPJ).



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

- **Especificação (geração de conteúdo):** com o GitHub Spec Kit e o Claude Code, a transcrição virou constituição, especificação (10 histórias, requisitos FR, critérios de sucesso SC), clarificações, plano, modelo de dados, contrato OpenAPI e 176 tarefas (T001–T176).
- **Implementação (automação):** agentes de IA trabalharam em paralelo, um por área (backend .NET, área Jotanunes em React e portal em React), cada um restrito à sua pasta; um orquestrador revisou, integrou, testou e fez os commits.
- **Testes (automação):** os agentes escreveram os testes antes do código (TDD) — 728 testes automatizados, todos aprovados — e conduziram os roteiros ponta a ponta (E2E) no navegador (Playwright), com `curl` e `psql`.
- **Qualidade dos artefatos (automação):** `speckit-analyze` (consistência entre spec, plano e tarefas) e `speckit-converge` (código × spec), que encontraram lacunas reais corrigidas antes da entrega.
- **Documentação (geração de conteúdo):** diagramas (Mermaid), documentação do produto e este relatório gerados com agentes e revisados.

Oportunidades de IA no produto (proposta, não implementado):

Oportunidade	Tipo	Valor	Situação
Extrair automaticamente do arquivo enviado a data de emissão, a data de validade, o órgão emissor e o CNPJ das certidões (OCR + modelo de linguagem)	Automação	Elimina a digitação e a conferência manual de datas; base para controlar vencimento (hoje fora do escopo da v1)	Proposta
Alertar a Jotanunes e a empresa antes do vencimento de certidões e estimar quais empresas têm risco de ficar irregulares	Predição	Evita que a empresa atue na obra com certidão vencida	Proposta
Verificar se o arquivo corresponde ao tipo de documento pedido (ex.: CND Municipal enviada no lugar da Federal) e se o CNPJ do documento é o da empresa	Predição (classificação)	Recusa precoce de envios errados, menos ciclos de rejeição e reenvio	Proposta
Detectar documento ilegível (foto escura, cortada, desfocada) no momento do envio, ainda no portal	Predição (classificação)	A empresa corrige na hora, sem esperar a análise	Proposta
Pré-triagem para o analista: resumo do documento com os pontos a conferir e divergências encontradas	Geração de conteúdo	Análise mais rápida; o analista decide com mais informação	Proposta



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Oportunidade	Tipo	Valor	Situação
Sugerir um texto claro para o motivo da rejeição, a partir do que foi detectado	Geração de conteúdo	Motivos mais objetivos, menos dúvidas da terceirizada	Proposta

Em todas as propostas, a IA **sugere** e o administrador da Jotanunes **decide**: aprovar e rejeitar continuam sendo ações humanas, registradas com autor, data e motivo.

Personas

Nomes fictícios.

Persona 1 — Mariana Couto, administradora da Jotanunes

- **Papel:** colaboradora com perfil de administrador na área Jotanunes; responde pela documentação das terceirizadas.
- **Objetivos:** manter o cadastro de obras, empresas e tipos de documento em dia; analisar rapidamente o que chega; saber quais empresas estão irregulares antes de liberar o serviço na obra.
- **Dores:** documentos chegam por e-mail e mensagens, misturados; não sabe com certeza qual é a versão mais recente; motivos de recusa se perdem; precisa conferir datas e CNPJ de cada certidão à mão.
- **Como usa o sistema:** entra pelo login próprio (ou pelo Fluig, quando a TI configurar), cadastra obras e empresas, vincula empresas às obras, ajusta o catálogo de tipos, trabalha a fila de análise (aprova ou rejeita com motivo) e gerencia os usuários internos na tela "Usuários".
- **Como a IA a ajudará (proposta):** pré-triagem com datas, emissor e CNPJ já extraídos e divergências destacadas; sugestão do texto do motivo de rejeição; alerta de certidões perto do vencimento.

Persona 2 — Rafael Nogueira, analista da Jotanunes (usuário comum)

- **Papel:** colaborador que acompanha as obras e cobra as empresas, sem alterar cadastros nem decidir análises.
- **Objetivos:** saber, por obra, quais empresas têm pendência; convidar e reconvidar empresas assim que o contrato é fechado.
- **Dores:** precisa perguntar a várias pessoas o que já foi entregue; não tem uma visão por obra.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

- **Como usa o sistema:** consulta o painel (envios em análise, empresas com pendência, convidadas sem primeiro acesso), o detalhe das obras e das empresas, os históricos e os arquivos; envia e reenvia convites. As ações de administrador não aparecem para ele, e a API as recusa (403 SEM_PERMISSAO).
- **Como a IA o ajudará (proposta):** lista priorizada das empresas com maior risco de ficar irregulares (predição de vencimento) e lembretes automáticos.

Persona 3 — Carla Mendes, representante da empresa terceirizada

- **Papel:** responsável administrativa de uma empresa contratada para uma ou mais obras (ex.: "Instaladora Horizonte Ltda.", fictícia); usa o celular com frequência.
- **Objetivos:** saber exatamente o que enviar, enviar rápido e entender por que algo foi recusado.
- **Dores:** listas de documentos passadas por mensagem, sem retorno claro; não sabe se o arquivo chegou nem se foi aceito; recusas sem explicação.
- **Como usa o sistema:** recebe o convite por e-mail, entra no portal com CNPJ e a senha provisória, cria a própria senha, vê os documentos exigidos com a situação em texto (Pendente de envio, Em análise, Aprovado, Rejeitado), envia PDF/JPEG/PNG de até 10 MB, lê o motivo das rejeições e reenvia.
- **Como a IA a ajudará (proposta):** aviso imediato, ainda no envio, de que a foto está ilegível ou de que o arquivo não parece ser o documento pedido; alerta antes de a certidão vencer.

Persona 4 — Bruno Farias, TI da Jotanunes (Fluig e servidor)

- **Papel:** integra a área Jotanunes ao Fluig (token de identidade assinado e grupo de administradores) e opera o servidor.
- **Objetivos:** controlar quem acessa o sistema a partir dos perfis do Fluig; instalar e manter o sistema com segurança.
- **Dores:** sistemas que exigem mais um cadastro de usuários; segredos espalhados; falta de trilha de auditoria.
- **Como usa o sistema:** configura a abertura pelo Fluig com o papel admin no token; na instalação, roda o comando `criar-admin` para criar o primeiro administrador interno; consulta a auditoria e os logs em JSON (sem senhas nem tokens).



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

- **Como a IA o ajudará (proposta):** sem uso direto de IA no papel dele; caberia a ele aprovar o provedor de IA (contrato, LGPD, custo) e monitorar a disponibilidade e a latência do serviço de IA, com o sistema funcionando normalmente sem ele.

Persona 5 — Jotanunes Construtora, dona do produto (organização)

- **Papel:** representada pela pessoa que conduziu o levantamento de requisitos e pelo dono do produto que validou as decisões.
- **Objetivos:** processo único, rastreável e alinhado à LGPD para comprovar a regularidade fiscal, trabalhista e técnica das contratadas.
- **Dores:** risco jurídico e trabalhista de manter terceirizada irregular na obra; dependência da memória de quem cuida do processo.
- **Como usa o sistema:** define quais documentos são exigidos e valida as regras de negócio registradas na especificação.
- **Como a IA a ajudará (proposta):** visão consolidada de vencimentos futuros e indicadores de tempo de análise e de taxa de rejeição por tipo de documento.

1.2- Cenários de Uso e Casos de Borda (Edge Cases) de IA:

- Identificar cenários de falha, casos críticos de erro.

Cenários de uso principais

1. **Cadastro e convite:** a administradora cadastra a obra, a empresa (razão social, CNPJ, e-mail) e a vincula à obra; clica em "Enviar convite" e a empresa recebe o link do portal e uma senha provisória (7 dias).
2. **Primeiro acesso:** a terceirizada abre o link (CNPJ já preenchido), entra com a senha provisória e é obrigada a criar a própria senha antes de ver qualquer dado.
3. **Envio de documentos:** a terceirizada vê os documentos exigidos ("Pendente de envio") e envia um arquivo para cada; a situação passa a "Em análise".
4. **Análise:** a administradora abre a fila (mais antigos primeiro, filtros por obra, empresa e tipo), abre o arquivo e aprova, ou rejeita com motivo; na rejeição, a empresa recebe e-mail com o motivo.
5. **Reenvio:** a terceirizada vê "Rejeitado" e o motivo, envia um novo arquivo e o ciclo recomeça; o histórico guarda todos os envios.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA
SQUAD: 81

- 6. Acompanhamento:** o analista (usuário comum) consulta o painel e o detalhe da obra ("4 de 6 aprovados") e reenvia convites, sem poder alterar cadastros nem decidir.
- 7. Gestão de acesso interno:** a administradora cadastra colegas na tela "Usuários", define o perfil, redefine senhas e desativa quem saiu da empresa; na instalação, a TI cria o primeiro administrador por comando.

Casos de borda e de falha críticos — produto



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Cenário	Risco	Comportamento do sistema hoje	Como seria com IA (proposta)
Arquivo corrompido, truncado, vazio ou com extensão trocada (ex.: .exe renomeado para .pdf)	Documento inútil ou malicioso entrar na análise	Formato conferido pelos bytes iniciais e verificação estrutural do final do arquivo: 415 ARQUIVO_TIPO_NAO_SUPORTADO ou 400 ARQUIVO_INVALIDO	Além da validação atual, checar legibilidade e se o conteúdo corresponde ao tipo pedido
Arquivo acima de 10 MB	Sobrecarga de disco e de rede	Validação no portal antes do envio e no servidor: 413 ARQUIVO_MUITO_GRANDE, com o formato e o tamanho aceitos na mensagem	—
Convite expirado (mais de 7 dias sem primeiro acesso)	Senha provisória vazada ser usada tarde	Acesso recusado: "Seu convite expirou. Peça um novo convite à Jotanunes."; reenvio invalida link e senha anteriores	—
Link de convite adulterado, já usado ou substituído	Acesso indevido	"Este link não é mais válido."; token guardado só como hash, validado por POST (fora de logs e do histórico)	—
Senha errada repetida (força bruta) e tentativa de descobrir CNPJ ou login cadastrado	Invasão de conta; enumeração de empresas	Bloqueio de 15 min após 5 falhas, também para CNPJ ou login inexistente; mesma mensagem e mesmo tempo de resposta nos dois casos; limite de requisições por IP	Detecção de padrões anômalos de login (predição), como apoio ao bloqueio
Sessão expirada no meio do upload	Empresa achar que enviou e não ter enviado	API responde 401; o portal leva ao login com "Sua sessão expirou. Entre de novo." e o arquivo precisa ser enviado de novo	—
Dupla análise concorrente (duas pessoas decidindo o mesmo envio)	Decisões contraditórias	Atualização condicional no banco: só a primeira vale; a segunda recebe 409 ENVIO_JA_ANALISADO	—
Dois envios simultâneos para o mesmo documento (duas abas)	Dois arquivos "Em análise"	Índice parcial no banco garante um único envio vivo; o segundo recebe 409 ENVIO_NAO_PERMITIDO	—
Serviço de e-mail (Resend) fora do ar no convite ou no cadastro de usuário	Empresa marcada como convidada sem ter recebido nada	Ordem grava → envia → confirma; na falha, 502 EMAIL_FALHOU ("Não conseguimos enviar o convite. Tente de novo em alguns minutos.") e nada é gravado	—



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Cenário	Risco	Comportamento do sistema hoje	Como seria com IA (proposta)
Resend fora do ar na rejeição	Empresa não saber da rejeição	Decisão mantida; aviso no log; a empresa vê "Rejeitado" e o motivo no próximo acesso	—
Empresa desativada	Ex-contratada continuar enviando ou consultando	Acesso recusado na hora (sessão derrubada pela versão da credencial); convite recusado; ao reativar, volta com a senha que tinha	—
CNPJ alfanumérico (formato da Receita Federal vigente desde julho de 2026) e CNPJ com ou sem máscara	Recusar empresa válida ou duplicar cadastro	Dígitos verificadores validados nos dois formatos; armazenado sem máscara; duplicidade recusada (409 CNPJ_DUPLICADO)	OCR conferir o CNPJ impresso no documento com o cadastrado
Tentativa de desativar ou tirar o papel do último administrador interno (ou de si mesmo)	Sistema ficar sem ninguém que o administre	Recusa: "O sistema precisa de pelo menos um administrador ativo." e "Você não pode desativar nem tirar o seu próprio acesso de administrador."; corrida entre dois administradores resolvida por trava exclusiva	—
Token do Fluig inválido (expirado, segredo, emissor ou audiência errados, alg=none, validade acima de 8 h) ou claim roles em formato inesperado	Acesso indevido ou elevação de privilégio	401 NAO_AUTENTICADO e tela de login próprio (ou "Abra este sistema pelo Fluig." se o login próprio estiver desligado); roles ausente, vazia, em maiúsculas ou de tipo inesperado → usuário comum	—
Usuário comum chamando operação de administrador direto na API	Alteração sem permissão	403 SEM_PERMISSAO antes de validar dados ou procurar o recurso, sem nenhum efeito; tentativa registrada na auditoria	—
Empresa A tentando acessar documento da empresa B (alterando endereços)	Vazamento de dados (LGPD)	Empresa identificada só pelo token; resposta 404, como se o recurso não existisse	—

Casos de borda de IA — da proposta (não implementado)

Hoje nenhum destes casos ocorre, porque não há IA no produto: a análise é inteiramente humana. Eles orientam como a proposta deve ser construída.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Cenário	Risco	Comportamento do sistema hoje	Como seria com IA (proposta)
OCR lê a data de validade errada (ex.: troca dia e mês, lê a data de emissão como validade)	Certidão vencida tratada como válida, ou alerta falso	Não se aplica: a administradora lê o documento	Extração sempre exibida como sugestão com a confiança; abaixo do limiar, campo marcado "conferir manualmente"; datas impossíveis (validade antes da emissão, no passado) recusadas por regra clássica; confirmação humana obrigatória
Documento ilegível (foto escura, cortada, desfocada)	Extração inventada ou vazia	Não se aplica: a administradora rejeita com motivo	Classificador de legibilidade avisa a empresa no envio; sem leitura confiável, nenhum campo é preenchido automaticamente
Falso positivo (IA diz que o arquivo é o documento certo e não é)	Documento errado aprovado	Não se aplica	IA nunca aprova: a decisão é sempre humana; o resultado da IA aparece como apoio, nunca como selo de aprovado
Falso negativo (IA diz que o arquivo está errado e está certo)	Retrabalho e atrito com a terceirizada	Não se aplica	IA não bloqueia o envio: apenas avisa; a empresa pode enviar mesmo assim e o analista decide
Alucinação no resumo ou no motivo de rejeição sugerido (texto com fato que não está no documento)	Rejeição injusta ou informação falsa à empresa	Não se aplica: o motivo é digitado pela administradora	Resumo restrito a campos extraídos com referência ao trecho do documento; motivo sugerido sempre editável e só enviado após confirmação humana
Serviço de IA indisponível, lento ou com resposta inesperada	Fila de análise travada	Não se aplica	Processamento assíncrono com tempo limite; na falha, o envio segue para a fila sem os campos sugeridos (o processo atual continua funcionando)
Dados pessoais enviados a um provedor externo de IA	Violação da LGPD	Não se aplica: os arquivos não saem do servidor	Provedor com contrato e cláusula de não treinamento, ou modelo local; registro na auditoria de cada processamento

Casos de borda do uso de IA no processo (ocorridos e tratados)



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Cenário	Risco	O que aconteceu e como foi tratado
Agente gerando código que diverge do contrato OpenAPI	Front e API incompatíveis	Regra: nenhum agente edita o contrato; divergência é reportada ao orquestrador. Teste de contrato confere as 43 operações, <code>operationId</code> , enumerados, DTOs, títulos de erro e <code>x-requer-admin</code> ; os tipos dos fronts são gerados do contrato. Uma descrição que tornava o YAML inválido foi detectada e corrigida, com os tipos regenerados
Agente marcar como pronto algo que não cumpre a spec	Requisito de segurança faltando em produção	<code>speckit-converge</code> encontrou 6 lacunas (T117-T122), entre elas o bloqueio de login que só existia para CNPJ cadastrado (revelava quais CNPJs existiam), arquivo truncado aceito e recusas de login fora da auditoria; todas corrigidas com testes
Segredo de desenvolvimento chegando à produção	Tokens forjáveis em produção	Na preparação da publicação, verificou-se que a configuração de produção podia herdar os segredos de assinatura do desenvolvimento; o script de publicação passou a ler os segredos só de um arquivo fora do git e a parar se faltarem, forem fracos ou repetidos; a API não sobe com segredo inseguro
Decisão do usuário conflitando com a constituição	Regra de segurança violada sem perceber	<code>speckit-analyze</code> apontou que o adaptador de e-mail de desenvolvimento grava o e-mail (com senha provisória) no log, o que a constituição proibia; virou exceção explícita e restrita ao desenvolvimento (constituição 1.0.1)
Agente sem humano para responder ao <code>clarify</code>	Suposição tratada como requisito	As respostas foram registradas como "Decisão assumida (a validar)" e depois validadas pelo dono do produto (ver 1.3)
Defeito que os testes unitários não pegaram (integração real)	Ação aplicada ao registro errado	No E2E e na revisão, o orquestrador encontrou que um modal de aprovação aberto no envio A podia aprovar o envio B ao navegar entre detalhes; corrigido com 10 testes de regressão
Agentes paralelos editando os mesmos arquivos	Conflitos e perda de trabalho	Fronteira de pastas: cada tarefa tem uma única área (<code>backend/</code> , <code>fluig-app/</code> , <code>portal/</code> , <code>raiz</code>) e nenhuma exige editar arquivos de outra
Transcrição automática errando nomes próprios	Requisito com nome errado ("JET News", "fluido", "esse IPJ")	Revisão humana da transcrição com correção manual dos nomes, registrada no topo do arquivo



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

1.3- Entrevistas e Validação de Hipóteses: (OPCIONAL)

- Relatório de entrevistas **COM HUMANOS** e **COM AGENTES INTELIGENTES** focando:
 - Descoberta dos pontos de dor
 - Validação do problema;
 - Pelo menos uma entrevista com humanos.

(a) Entrevista com humano

- **Data:** 28/09/2026 (áudio de WhatsApp gravado às 21h24, duração de 4 min 16 s).
- **Participantes (por papel):** representante da Jotanunes que apresentou o desafio e integrante da Squad 81 (entrevistador). A conversa retoma combinações feitas "durante essas semanas" com o cliente.
- **Registro:** áudio transcrito localmente com *faster-whisper* (modelo "medium") e revisado à mão (docs/transcricao.txt).

Pontos de dor descobertos:

- A Jotanunes precisa "acionar essas empresas para que elas anexem os documentos que são necessários, para que eles consigam analisar isso" — hoje não há plataforma para isso.
- Falta um gatilho formal para o início do processo: "já fechamos o contrato, manda os meus documentos".
- O controle de quem, dentro da Jotanunes, pode cadastrar e analisar deve seguir os perfis que a empresa já usa (Fluig).
- A terceirizada precisa de um acesso próprio, simples, só para anexar o que é exigido.

Hipóteses validadas na conversa:

Hipótese	Evidência na entrevista	Resultado
São dois sistemas: um da Jotanunes (integrado ao Fluig) e outro da terceirizada	"pode pensar que são dois sistemas diferentes"	Validada
A organização é obra → empresas → documentos	"Então é obra, empresas e das empresas os documentos." — "Exatamente."	Validada



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Hipótese	Evidência na entrevista	Resultado
Os tipos de documento são os mesmos para todas as empresas	"Os mesmos tipos."	Validada
O convite é por e-mail com link para o sistema	"A primeira forma é enviar um e-mail [...] um linkzinho dele, clique, acessa o sistema"	Validada
A terceirizada entra com CNPJ e senha	"O combinado foi ser CNPJ e senha"	Validada
A área Jotanunes não precisa de login próprio, pois o Fluig controla o acesso	"Não precisa-se de um login. Porque o próprio Fluig já tem esse contrato de perfil"	Validada em 28/09; revista em 29/09 (ver abaixo)

Decisões que ficaram para validar e como foram validadas depois:

Ponto em aberto	Como ficou na entrevista	Validação posterior (dono do produto)
Quem define a senha da empresa	"vê o Gustavo, o que ele prefere" — duas opções: Jotanunes define, ou o sistema gera e a empresa troca no primeiro acesso	VALIDADA em 29/09/2026: o sistema gera senha temporária, enviada no mesmo e-mail do link, com troca obrigatória no primeiro acesso
Documentos por empresa ou por empresa + obra	Implícito ("das empresas os documentos")	VALIDADA em 29/09/2026: por empresa; um envio vale para todas as obras ("tem várias empresas por obra e documentos por empresa")
Seleção de documentos por empresa	"Os mesmos tipos"	VALIDADA em 29/09/2026: todos os tipos ativos para todas as empresas ativas
Todos os usuários do Fluig com as mesmas permissões	Não discutido	VALIDADA em 29/09/2026 (nova decisão): perfis administrador e comum, com o papel vindo do Fluig
Acesso só pelo Fluig	"Não precisa-se de um login"	VALIDADA em 29/09/2026 (tarde), substituindo a anterior: a Jotanunes ainda não tem acesso ao Fluig; a área Jotanunes ganha login próprio além do Fluig, com usuários internos na tela "Usuários" e primeiro administrador criado na instalação
Catálogo inicial de tipos de documento	"a gente já sabe quais são os documentos"	VALIDADA em 29/09/2026: instalação nova já sobe com 10 tipos padrão (Cartão CNPJ, Contrato Social, CNDs Federal/Estadual/Municipal, CRF do FGTS, CNDT, PGR, PCMSO, ART/RRT)



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Ponto em aberto	Como ficou na entrevista	Validação posterior (dono do produto)
Formatos e tamanho (PDF/JPEG/PNG até 10 MB), prazo do convite (7 dias), bloqueio (5 falhas/15 min), sessão de 8 h	Não discutido	Continuam como "decisões assumidas" registradas na spec, a confirmar com a Jotanunes

(b) Entrevistas com agentes inteligentes

As etapas do Spec Kit funcionaram como entrevistas estruturadas em que o agente de IA questionou a especificação. As respostas ficaram registradas na seção *Clarifications* da `spec.md`, com data e origem.

Sessão `speckit-clarify` de 28/09/2026 (sem humano disponível). A primeira versão da spec tinha 3 marcadores [NEEDS CLARIFICATION]. O agente fez as 5 perguntas permitidas e, sem humano para responder, adotou a opção recomendada, marcada "Decisão assumida (a validar com Gustavo/Jotanunes)":

Pergunta do agente	Decisão proposta	Resultado
Quem define a senha da empresa no portal?	Sistema gera senha temporária aleatória enviada no convite; troca obrigatória no primeiro acesso	Validada pelo dono do produto em 29/09
Documentos exigidos por empresa ou por empresa + obra?	Por empresa; o vínculo com a obra serve para organizar e filtrar	Validada em 29/09
Quais tipos são exigidos de cada empresa?	Todos os tipos ativos de todas as empresas ativas	Validada em 29/09
Quais formatos e tamanho de arquivo?	PDF, JPEG e PNG, até 10 MB, um arquivo por envio	Mantida como decisão assumida
A senha temporária pode ir no mesmo e-mail do link?	Sim, mitigada por expiração em 7 dias, uso único e troca obrigatória	Validada em 29/09

Além das 5 perguntas, o agente listou em "Outras decisões assumidas" os pontos decididos pela opção mais razoável (prazo do convite, bloqueio, sessão de 8 h, e-mail só na rejeição, nada excluído pela interface, CNPJ imutável após o convite), para validação posterior.

Sessões de 29/09/2026 (com o dono do produto). O agente reabriu as decisões assumidas e levou as novas necessidades à spec: perfis administrador/comum (US6), catálogo padrão (US7) e login próprio com usuários internos (US8–US10). Para



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

o login próprio, o agente derivou e registrou como "decisões técnicas derivadas" (research R17): senha provisória com as mesmas regras do portal, revogação imediata das sessões ao mudar papel ou desativar, regra do último administrador e chave para desligar o login próprio.

Análises que descobriram lacunas:

Etapa	Achado do agente	Resultado
Checklist de qualidade da spec	3 marcadores de ambiguidade (fluxo de senha, documentos por empresa x obra, formatos e tamanho)	Resolvidos no <code>clarify</code> ; checklist de 15/16 para 16/16
speckit-analyze (28/09)	Conflito entre a decisão de registrar o e-mail no log em desenvolvimento e a regra da constituição que proíbe senhas em log	Constituição 1.0.1 com exceção explícita e restrita ao adaptador de desenvolvimento
speckit-converge (29/09)	Bloqueio de 5 falhas só para empresas convidadas, permitindo descobrir se um CNPJ existe	T117: contador por HMAC para CNPJs sem cadastro e BCrypt fictício para igualar o tempo de resposta
speckit-converge (29/09)	Arquivo com cabeçalho válido mas truncado era aceito	T118: verificação estrutural do final do arquivo (400 ARQUIVO_INVALIDO)
speckit-converge (29/09)	Recusas de login por empresa desativada e por senha temporária vencida não entravam na auditoria	T119: registro LOGIN_FALHA
speckit-converge (29/09)	Histórico de tipos desativados inacessível na área Jotanunes; fluxos de tela sem testes	T120 e T121
speckit-converge (29/09)	Logs fora de desenvolvimento não estavam em JSON estruturado	T122

2. BACKLOG E ENGENHARIA DE REQUISITOS "AI-FIRST"

2.1- Backlog Priorizado e Categorizado:

- Épicos;
- Histórias de usuários;
- Detalhamento das tarefas das histórias de usuário
- Descrição dos padrões de uso de ferramentas de IA no projeto.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Épicos

Épico	Objetivo	Histórias	Prioridade
E1 — Cadastros e catálogo	Ter a quem pedir e o que pedir: obras, empresas, vínculos e tipos de documento, com catálogo padrão na instalação	US1, US7	P1 (US1), P2 (US7)
E2 — Convite e acesso da terceirizada	Disparar o processo por e-mail e dar à empresa um acesso seguro por CNPJ e senha	US2	P1
E3 — Envio e análise de documentos	Receber os arquivos, analisar (aprovar/rejeitar com motivo) e permitir o reenvio	US3, US4	P1 (US3), P2 (US4)
E4 — Acompanhamento	Indicadores e visão por obra e por empresa	US5	P3
E5 — Controle de acesso da área Jotanunes	Perfis, login próprio, gestão de usuários internos e primeiro administrador	US6, US8, US9, US10	P1

Histórias de usuário

ID	História	Prioridade	Épico
US1	Como administradora da Jotanunes (Mariana), quero cadastrar tipos de documento, obras e empresas e vincular empresas às obras, para saber de quem pedir e o que pedir	P1	E1
US2	Como administradora ou analista da Jotanunes , quero enviar um convite por e-mail com link e senha provisória, para que a empresa contratada comece a enviar os documentos	P1	E2
US3	Como representante da terceirizada (Carla), quero ver os documentos exigidos e enviar os arquivos pelo portal, para cumprir as exigências e acompanhar a situação de cada um	P1	E3
US4	Como administradora da Jotanunes , quero aprovar ou rejeitar cada envio com motivo, e a terceirizada quer ver o motivo e reenviar, para fechar o ciclo de análise com rastreabilidade	P2	E3
US5	Como analista da Jotanunes (Rafael), quero um painel e a situação por obra e por empresa, para cobrar as pendências certas	P3	E4
US6	Como Jotanunes , quero que só administradores cadastrem, alterem e analisem, enquanto usuários comuns consultam e convidam, para controlar quem decide	P1	E5
US7	Como administradora da Jotanunes , quero que uma instalação nova já venha com os 10 tipos de documento mais comuns, para começar a usar sem digitar o catálogo	P2	E1



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

ID	História	Prioridade	Épico
US8	Como colaborador da Jotanunes , quero entrar na área Jotanunes com login e senha próprios, para usar o sistema enquanto o Fluig não está disponível	P1	E5
US9	Como administradora da Jotanunes , quero cadastrar, editar, desativar e redefinir a senha dos usuários internos, para controlar quem tem acesso	P1	E5
US10	Como TI da Jotanunes (Bruno), quero criar o primeiro administrador por um comando no servidor, para que alguém consiga entrar numa instalação nova	P1	E5

Detalhamento das tarefas

As 176 tarefas (T001–T176) estão em `specs/001-portal-documentos-terceirizadas/tasks.md`, cada uma com exatamente uma área: [BACKEND] (API .NET 8), [FLUIG] (área Jotanunes, React), [PORTAL] (portal da terceirizada, React) e [INFRA] (raiz, scripts, deploy). Os testes de cada história vêm antes da implementação.

Base (todas as histórias): Setup T001–T011 (compose do PostgreSQL, `.env.example`, script de token do Fluig de desenvolvimento, solução .NET, projetos Vite) e Fundação T012–T042 — backend T012–T025 (CNPJ numérico e alfanumérico, entidades, DbContext, migration, erros no padrão do contrato, autenticação Fluig e Portal, validação da configuração, infraestrutura de testes com Testcontainers), área Jotanunes T026–T034 (tokens visuais, cliente gerado do contrato, leitura do token Fluig, mocks MSW, componentes base) e portal T035–T042 (idem, sessão e rotas).

História	Backend	Área Jotanunes (FLUIG)	Portal / Infra
US1	Testes T043–T047 (domínio, obras, empresas, vínculos e tipos, autorização em todas as rotas); implementação T048–T054 (regras, repositórios, consulta de situação, casos de uso e endpoints)	T055–T059 (mocks, telas de tipos, obras, empresas e testes)	—
US2	Testes T060–T063 (convite, acesso, troca de senha); implementação T064–T069 (política de senha, BCrypt, tokens, Resend, modelo de e-mail, casos de uso, rate limiter)	T070–T072 (seção "Acesso ao portal", enviar/reenviar convite)	Portal T073–T076 (tela de acesso, troca de senha, testes)



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

História	Backend	Área Jotanunes (FLUIG)	Portal / Infra
US3	Testes T077-T079 (detector de formato, documentos, isolamento entre empresas); implementação T080-T083 (armazenamento, envio, download, endpoints com limite de 11 MB)	—	Portal T084-T088 (componente de envio, "Meus documentos", histórico, testes)
US4	Testes T089-T090; implementação T091-T093 (aprovar/rejeitar, fila, concorrência, e-mail de rejeição)	T094-T098 (fila de análise, tela de análise, histórico por empresa)	Portal T099-T100 (rejeitado com motivo e reenvio)
US5	T101-T102 (painel e filtros)	T103-T105 (painel com indicadores e filtros)	—
Transversal	T106-T109 (teste de contrato, desempenho com 20.000 envios, cabeçalhos de segurança)	T110-T112 (proibição de framework CSS, acessibilidade)	Portal T113-T115; E2E T116
Convergência	T117-T119, T122 (bloqueio sem enumeração, arquivo truncado, auditoria, log JSON)	T120-T121	—
US6	T123-T130 (perfil pela claim roles, teste que percorre todas as rotas de escrita, política FluigAdmin, auditoria com perfil)	T136-T143 (perfil na interface, SomenteAdmin, modo leitura, testes de 403)	Infra T135 (token --admin); Portal T144; E2E T145
US7	T131-T134 (catálogo de 10 tipos, semeador idempotente com trava exclusiva)	—	—
US8	T146-T149, T153, T155-T160 (domínio do usuário interno, login, troca de senha, esquema LoginLocal, configuração)	T165-T169, T172 (sessão, tela de login, troca de senha, testes)	Portal T175
US9	T150-T152, T161 (revogação de sessões, gestão de usuários, regra do último administrador, e-mail de acesso)	T170-T171, T173-T174 (menu, tela "Usuários", testes)	—
US10	T154, T162 (comando criar-admin)	—	Infra T163-T164 (documentação e deploy); E2E T176

Padrões de uso de ferramentas de IA no projeto

- **Desenvolvimento orientado por especificação (GitHub Spec Kit):** constituição → specify → clarify → plan → tasks → analyze → implement → converge, repetido a cada



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

rodada de requisitos (versão inicial, perfis e catálogo, login próprio). Toda mudança começa pela spec; textos substituídos ficam riscados com data, sem apagar o histórico.

- **Agentes paralelos com fronteira de pastas:** um agente por área (BACKEND, FLUIG, PORTAL; nas rodadas seguintes, BACKEND+INFRA e FLUIG), cada um editando apenas a sua pasta. Os fronts trabalham contra mocks (MSW) que seguem o contrato, sem esperar o backend.
- **Orquestrador revisa, integra e faz os commits:** os agentes não fazem commit; o orquestrador revisa cada entrega, roda as suítes, integra as três áreas e registra commits por grupo lógico de tarefas.
- **TDD:** testes escritos antes, vistos falhando, e só então a implementação; tarefa só termina com a suíte verde.
- **Contrato como fonte de verdade:** `contracts/openapi.yaml` (versão 1.2.0, 43 operações) é lido por todos e editado por nenhum agente; divergência é reportada ao orquestrador.
- **Verificação cruzada por IA:** `speckit-analyze` antes de implementar e `speckit-converge` depois, com as lacunas viradas em tarefas numeradas.
- **E2E conduzido por agente:** roteiro do `quickstart.md` (56 passos) executado com as áreas integradas, no navegador (Playwright), com `curl` e `psql`, ao fim de cada rodada (T116, T145, T176).
- **Regras fixas:** nenhum segredo, senha, token ou e-mail real em código, commits ou documentos (segredos de produção só em arquivo fora do git); commits sem linha de coautoria de ferramenta; decisões assumidas pela IA marcadas como "a validar" até o dono do produto confirmar.

2.2- Histórias de Usuário e Critérios de Aceite de IA:

- Definição clara dos critérios de aceitação e como garantir que o resultado das ferramentas de IA está funcionando corretamente.

Critérios de aceite



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

História	Critério de aceite (Dado / Quando / Então)
US1	Dado a tela de empresas, quando a administradora cadastra uma empresa com CNPJ válido, razão social e e-mail, então a empresa aparece na lista com acesso "Não convidada".
US1	Dado uma empresa com o CNPJ 12.345.678/0001-95, quando se tenta cadastrar outra com o mesmo CNPJ (com ou sem máscara), então o sistema recusa e informa que o CNPJ já está cadastrado.
US1	Dado um CNPJ (numérico ou alfanumérico) com dígito verificador inválido, quando a administradora salva, então o sistema recusa e indica o campo CNPJ.
US2	Dado uma empresa com e-mail de contato, quando se clica em "Enviar convite", então o e-mail sai com link, nome da empresa, obras e instruções, e a empresa passa a "Convidada".
US2	Dado um convite válido, quando a empresa entra com CNPJ e a senha do convite, então o portal exige "Crie uma nova senha para continuar." e não mostra outra tela até a troca.
US2	Dado um convite com mais de 7 dias sem primeiro acesso, quando a empresa tenta entrar, então vê "Seu convite expirou. Peça um novo convite à Jotanunes."
US3	Dado uma empresa autenticada e 3 tipos ativos, quando abre "Meus documentos", então vê os 3 com nome, instruções e situação escrita (não só cor).
US3	Dado um arquivo em formato não aceito ou acima de 10 MB, quando a empresa tenta enviar, então o envio é recusado com mensagem dizendo o formato e o tamanho aceitos.
US3	Dado a empresa A autenticada, quando tenta ver, baixar ou enviar documento da empresa B, então o sistema responde como se o recurso não existisse.
US4	Dado um envio "Em análise", quando a administradora rejeita sem motivo, então o sistema recusa e pede o motivo.
US4	Dado um envio "Em análise", quando rejeita com motivo, então a situação passa a "Rejeitado", ficam registrados usuário, data/hora e motivo, e a empresa recebe e-mail com o motivo.
US4	Dado duas pessoas abrindo o mesmo envio, quando a segunda decide depois da primeira, então o sistema recusa informando que o envio já foi analisado.
US5	Dado dados cadastrados, quando o analista abre o painel, então vê o total de envios em análise, de empresas com pendência e de convidadas sem primeiro acesso.
US5	Dado uma obra com empresas vinculadas, quando o analista abre a obra, então vê cada empresa com a contagem de documentos por situação.
US6	Dado um usuário comum, quando chama na API qualquer operação de administrador, então recebe 403 SEM_PERMISSAO, nada muda e a tentativa fica na auditoria.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

História	Critério de aceite (Dado / Quando / Então)
US6	Dado um usuário comum, quando abre o sistema, então vê painel, listas, detalhes e arquivos, sem os botões de administrador e com o aviso "Só administradores podem cadastrar, alterar ou analisar. Se você precisa, fale com a TI."
US6	Dado um usuário comum, quando envia ou reenvia o convite de uma empresa, então o convite é enviado normalmente.
US7	Dado um banco sem nenhum tipo de documento, quando a API sobe, então existem os 10 tipos padrão ativos com instruções.
US7	Dado o catálogo padrão já criado, quando a API reinicia (uma ou várias instâncias ao mesmo tempo), então nenhum tipo é duplicado.
US8	Dado o login próprio ligado e nenhum token, quando a área Jotanunes carrega, então aparece a tela de login e nenhum dado.
US8	Dado login inexistente ou senha errada, quando o usuário tenta entrar, então vê a mesma mensagem "Login ou senha incorretos." nos dois casos; após 5 erros, bloqueio de 15 minutos igual para os dois.
US8	Dado uma sessão de login próprio, quando o usuário clica em "Sair", então volta ao login e aquela sessão deixa de valer na API na hora.
US9	Dado o formulário "Novo usuário", quando a administradora salva nome, e-mail, login e perfil, então o usuário aparece como "Aguardando primeiro acesso", recebe o e-mail com a senha provisória e a senha não aparece na tela.
US9	Dado um usuário com sessão aberta, quando a administradora o desativa, então a próxima ação dele é recusada e ele não consegue entrar de novo.
US9	Dado um único administrador interno ativo, quando alguém tenta desativá-lo ou tirar o papel dele, então o sistema recusa com "O sistema precisa de pelo menos um administrador ativo."
US10	Dado nenhum administrador interno ativo, quando a TI roda o comando com login, nome e e-mail, então o administrador é criado, o e-mail sai e a senha provisória aparece só no terminal.
US10	Dado já existir administrador interno ativo, quando o comando roda sem a opção de forçar, então nada é criado nem alterado.
US10	Dado qualquer execução do comando, quando o log da aplicação é consultado, então a senha provisória não aparece nele.

Como garantimos que o resultado das ferramentas de IA está correto

O código foi escrito por agentes de IA; a correção foi garantida por verificações independentes do agente que escreveu o código:

- **Testes automatizados (728, todos aprovados em 29/09/2026):** backend 467 (domínio 104, aplicação 42, integração da API 321 contra PostgreSQL 16 real via



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Testcontainers), área Jotanunes 190 e portal 71 (Vitest + Testing Library + MSW). Escritos antes do código (TDD), a partir dos cenários de aceitação da spec.

- **Teste de contrato OpenAPI:** compara a API em execução com o `openapi.yaml` — 43 operações, rotas, `operationId`, enumerados, propriedades dos DTOs, títulos de erro e a marcação `x-requer-admin`. Um agente que inventasse rota ou campo quebraria o teste.
- **Testes de autorização em todas as rotas:** um teste enumera as rotas registradas na API e exige `403 SEM_PERMISSAO` para usuário comum e sucesso para administrador, nas duas origens de identidade (Fluig e login próprio); uma rota nova sem classificação faz o teste falhar (SC-009 e SC-012). Testes de isolamento garantem que a empresa B nunca vê dados da empresa A (SC-003).
- **Revisão humana e do orquestrador:** cada entrega dos agentes foi revisada antes do commit; decisões de negócio tomadas pela IA ficaram marcadas "a validar" até a confirmação do dono do produto.
- **E2E real:** roteiro de 56 passos com API, área Jotanunes, portal e banco integrados, executado ao fim de cada rodada (T116, T145, T176), incluindo bloqueio, revogação de sessão, concorrência e tokens cruzados.
- **speckit-analyze e speckit-converge:** verificação cruzada entre spec, plano, tarefas, constituição e código; a convergência gerou 6 tarefas de correção (T117–T122).
- **Regressões encontradas e corrigidas (com testes):** enumeração de CNPJ pelo bloqueio, arquivo truncado aceito, token do convite exposto na URL (passou a POST), modal de aprovação aplicado ao envio errado, IP real perdido atrás do proxy, risco de segredo de desenvolvimento em produção e YAML do contrato inválido — nenhum defeito conhecido em aberto.
- **Validação visual e de acessibilidade:** telas conferidas no navegador contra o guia visual (`docs/design.md`), contraste WCAG AA, uso a partir de 360 px e script que falha se algum framework de CSS for adicionado.

Critérios para a proposta de IA no produto (a adotar na próxima iteração):

Critério	Meta proposta
Precisão da extração de datas e CNPJ	Medida num conjunto de referência de documentos reais anonimizados, conferidos por pessoa; meta inicial de ao menos 95% de acerto exato por campo antes de liberar



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Critério	Meta proposta
Confiança mínima	Campo com confiança abaixo do limiar (ex.: 0,85) não é preenchido: aparece como "conferir manualmente"
Revisão humana obrigatória	A IA nunca aprova nem rejeita; toda decisão continua humana, com autor, data e motivo
Regras clássicas sobre a saída da IA	Datas impossíveis, CNPJ com dígito verificador inválido ou diferente do cadastrado são sinalizados sem depender do modelo
Falso positivo e falso negativo	Monitorados pela concordância entre a sugestão da IA e a decisão do analista; queda abaixo da meta desliga a sugestão
Rastreabilidade	Versão do modelo, confiança e resultado de cada processamento registrados na auditoria
Resiliência	Tempo limite e processamento assíncrono; com a IA fora do ar, o fluxo atual segue sem perda
LGPD	Provedor com contrato e sem uso dos dados para treinamento, ou modelo local; nada de documento em log
Testes	Conjunto de referência rodado como teste de regressão a cada mudança de modelo ou de prompt

3. BANCO DE DADOS E API

3.1- Representação da estrutura do banco de dados contendo:

- Entidades, Atributos, Relacionamentos, Chaves primárias e estrangeiras.
- Identificar no modelo de dados quais entidades ou estruturas estão relacionadas ao uso de IA no sistema (caso faça sentido).

O banco de dados é um **PostgreSQL 16** (base `jotanunes_docs`), criado e versionado pelas *migrations* do Entity Framework Core (`Inicial`, `TentativasLoginPorCnpj`, `PerfilAdminAuditoria` e `UsuariosInternos`), aplicadas automaticamente na subida da API. As tabelas e colunas seguem a convenção *snake_case*; as chaves primárias são `uuid` gerados pela aplicação (exceto `auditoria`, com chave numérica sequencial, e `tentativas_login`, cuja chave é um HMAC). O modelo está na terceira forma normal: a relação N:N entre obras e empresas é resolvida pela tabela associativa `obra_empresas`, e as situações derivadas (situação de acesso da empresa, situação do convite, situação de cada documento) **não são armazenadas** — são calculadas a partir dos dados. As

ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

colunas de autoria (criado_por_login, analisado_por_login etc.) guardam o login de quem agiu, sem chave estrangeira, porque o usuário pode vir do Fluig, onde não há cadastro local. Datas são gravadas em UTC (timestampz).

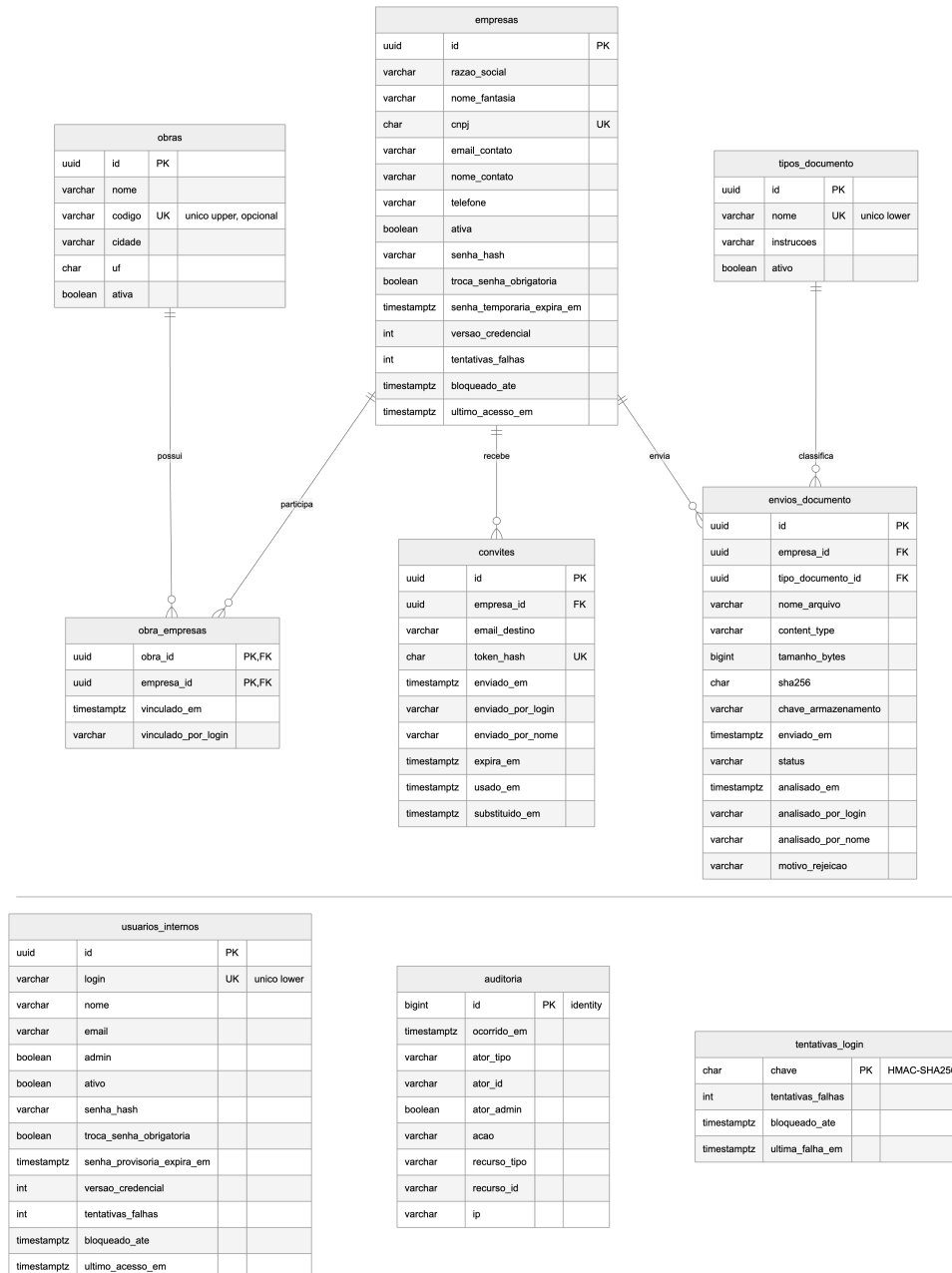


Figura 1 – Modelo lógico do banco de dados



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Entidade/ tabela	Atributos principais	PK	FKs/ relacionamentos	Observações
obras	nome, codigo, cidade, uf, ativa, colunas de autoria	id (uuid)	N:N com empresas via obra_empresas	Código único sem diferenciar maiúsculas, só quando preenchido (ix_ obras_codigo_ upper, índice parcial)
empresas	razao_social, nome_fantasia, cnpj, email_ contato, nome_ contato, telefone, ativa, senha_ hash, troca_ senha_ obrigatoria, senha_ temporaria_ expira_em, versao_ credencial, tentativas_falhas, bloqueado_ate, ultimo_acesso_ em	id (uuid)	1:N com convites e envios_documento; N:N com obras	CNPJ único (ix_ empresas_cnpj), numérico ou alfanumérico, imutável após o primeiro convite; senha só como hash BCrypt; versao_credencial revoga tokens
obra_empresas	vinculado_em, vinculado_por_ login	(obra_id, empresa_id)	obra_id → obras; empresa_id → empresas	Tabela associativa do vínculo empresa × obra
tipos_documento	nome, instrucoes, ativo, colunas de autoria	id (uuid)	1:N com envios_ documento	Nome único sem diferenciar maiúsculas (ix_ tipos_documento_ nome_lower); todo tipo ativo é exigido de toda empresa ativa
convites	email_destino, token_hash, enviado_em, enviado_por_ login, enviado_ por_nome, expira_em, usado_em, substituido_em	id (uuid)	empresa_id → empresas	Token do link guardado só como hash SHA-256 (único); validade de 7 dias; situação derivada (válido, usado, expirado, substituído)



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Entidade/ tabela	Atributos principais	PK	FKs/ relacionamentos	Observações
envios_ documento	nome_arquivo, content_type, tamanho_bytes, sha256, chave_ armazenamento, enviado_em, status, analizado_em, analizado_por_ login, analizado_ por_nome, motivo_rejeicao	id (uuid)	empresa_id → empresas; tipo_ documento_id → tipos_documento	status ∈ EM_ ANALISE, APROVADO, REJEITADO; um único envio "vivo" por empresa e tipo (ix_envios_ documento_vivo, índice único parcial); o arquivo fica em disco, a tabela guarda só a chave interna
usuarios_ internos	login, nome, email, admin, ativo, senha_ hash, troca_ senha_ obrigatoria, senha_ provisoria_ expira_em, versao_ credencial, tentativas_falhas, bloqueado_ate, ultimo_acesso_ em	id (uuid)	— (autoria por login)	Usuários do login próprio da área Jotanunes; login único sem diferenciar maiúsculas (ix_ usuarios_ internos_login_ lower)
auditoria	ocorrido_em, ator_tipo, ator_id, ator_admin, acao, recurso_ tipo, recurso_id, ip	id (bigint identity)	— (referências textuais ao recurso)	Trilha de auditoria somente de inclusão (logins, convites, envios, downloads, decisões, permissões negadas, gestão de usuários)
tentativas_ login	tentativas_falhas, bloqueado_ate, ultima_falha_em	chave (HMAC- SHA256)	—	Contador de bloqueio para CNPJ/login digitado que não existe, sem guardar o valor digitado (evita enumeração)

Todas as chaves estrangeiras usam ON DELETE RESTRICT: nada com dependentes é apagado, coerente com a regra de negócio de que registros são desativados, nunca



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

excluídos. Além dessas nove tabelas, o EF Core mantém a tabela técnica `EFMigrationsHistory`. A extensão `unaccent` do PostgreSQL é habilitada pela primeira *migration* para as buscas sem acento.

Estruturas relacionadas a IA

Na versão atual, nenhuma estrutura do banco se relaciona a IA: o produto não chama LLM, OCR nem modelo preditivo, e não há colunas ou tabelas de *embeddings*, extrações ou previsões.

Como **proposta para a próxima iteração (não implementado)**, a extração automática da data de validade e do emissor das certidões e a verificação de que o arquivo corresponde ao tipo de documento exigiriam, sem alterar as tabelas existentes:

Tabela proposta	Atributos	Relacionamento	Finalidade
<code>extracoes_documento</code>	<code>id</code> , <code>envio_id</code> , <code>status</code> (PENDENTE, PROCESSANDO, CONCLUIDA, FALHOU), <code>tipo_sugerido</code> , <code>tipo_confere</code> (bool), <code>data_emissao</code> , <code>data_validade</code> , <code>emissor</code> , <code>numero_documento</code> , <code>confianca</code> (0-1 por campo, em <code>jsonb</code>), <code>texto_extraido</code> (opcional), <code>modelo</code> , <code>versao_modelo</code> , <code>tentativas</code> , <code>erro</code> , <code>processado_em</code>	N:1 com <code>envios_documento</code> (um envio pode ter várias extrações, uma por reprocessamento)	Guardar o resultado da IA separado da decisão humana, com rastreabilidade de qual modelo e versão produziu cada valor
<code>revisoes_extracao</code>	<code>id</code> , <code>extracao_id</code> , <code>campo</code> , <code>valor_ia</code> , <code>valor_confirmado</code> , <code>revisado_por_login</code> , <code>revisado_em</code>	N:1 com <code>extracoes_documento</code>	Registrar a correção ou confirmação do analista (revisão humana obrigatória quando a confiança for baixa) e servir de base para medir a precisão do modelo

Nessa proposta, a data de validade confirmada permitiria alertar vencimentos, e a decisão de aprovar ou rejeitar continuaria sendo sempre do analista (colunas atuais de `envios_documento`).

3.2- Design da API e principais endpoints com métodos HTTP.

- Estrutura de requisições e respostas.

A API é REST, escrita em ASP.NET Core 8 (Minimal APIs), e implementa exatamente o contrato **OpenAPI 3** `specs/001-portal-documentos-terceirizadas/contracts/openapi.yaml`, versão **1.2.0**, com **43 operações**. O contrato é a fonte de verdade: os



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

tipos TypeScript dos dois fronts são gerados dele (`npm run gen:api`) e um teste automatizado do backend confere rotas, `operationId`, enumerados, esquemas e a marcação `x-requer-admin`.

A API atende dois públicos, em dois grupos de rotas isolados:

- **/api/fluig/* — área Jotanunes** (colaboradores). Aceita dois tipos de token JWT HS256: o emitido pelo **Fluig** (identidade do colaborador, com papel `admin` opcional) e o do **login próprio** (POST `/api/fluig/auth/login`). Operações marcadas com `x-requer-admin` exigem perfil administrador; usuário comum recebe 403 `SEM_PERMISSAO` antes de qualquer leitura de corpo ou banco.
- **/api/portal/* — portal da terceirizada**. Token JWT próprio, emitido por POST `/api/portal/auth/login` (CNPJ + senha). A empresa é identificada **sempre pelo token**, nunca por parâmetro; recurso de outra empresa responde 404.

Um token de uma área nunca é aceito na outra. Convenções: JSON em *camelCase*, enumerados em MAIÚSCULAS, datas ISO 8601 em UTC, listas paginadas com `pagina` e `tamanhoPagina` (1–100, padrão 20) e erros no formato **application/problem+json** (RFC 9457) com um campo `code` estável e mensagem em português pronta para exibir.

Método	Rota	Quem	Descrição
GET	/health	Anônimo	Verifica se a API está no ar
GET	/api/fluig/auth/configuracao	Anônimo	Informa se o login próprio está ligado
POST	/api/fluig/auth/login	Anônimo (10/min por IP)	Login próprio da área Jotanunes (login + senha)
POST	/api/fluig/auth/trocar-senha · /api/fluig/auth/sair	Login próprio	Troca a senha (devolve nova sessão) · encerra a sessão revogando o token
GET	/api/fluig/me · /api/fluig/painel	Área Jotanunes	Usuário atual (perfil, origem, troca pendente) · indicadores do painel
GET · POST	/api/fluig/obras	Todos · Admin	Lista obras (busca sem acento) · cadastra obra
GET · PUT	/api/fluig/obras/{obraId}	Todos · Admin	Detalhe com empresas vinculadas · atualiza, ativa ou desativa
PUT · DELETE	/api/fluig/obras/{obraId}/empresas/{empresaId}	Admin	Vincula (idempotente) · desvincula empresa da obra
GET · POST	/api/fluig/empresas	Todos · Admin	Lista empresas com contagem de documentos · cadastra empresa



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Método	Rota	Quem	Descrição
GET · PUT	/api/fluig/empresas/{empresaId}	Todos · Admin	Detalhe · atualiza, ativa ou desativa
GET · POST	/api/fluig/empresas/{empresaId}/convites	Área Jotanunes	Histórico de convites · envia ou reenvia o convite por e-mail
GET	/api/fluig/empresas/{empresaId}/documentos	Área Jotanunes	Situação de cada tipo de documento para a empresa
GET	/api/fluig/empresas/{empresaId}/documentos/{tipoDocumentoId}/envios	Área Jotanunes	Histórico de envios da empresa para o tipo
GET · POST	/api/fluig/tipos-documento	Todos · Admin	Lista · cadastra tipo de documento
GET · PUT	/api/fluig/tipos-documento/{tipoDocumentoId}	Todos · Admin	Detalhe · atualiza, ativa ou desativa
GET	/api/fluig/envios	Área Jotanunes	Fila de análise e busca por situação, obra, empresa e tipo
GET	/api/fluig/envios/{envioId} · /arquivo	Área Jotanunes	Detalhe do envio · download do arquivo (auditado)
POST	/api/fluig/envios/{envioId}/aprovar	Admin	Aprova um envio em análise
POST	/api/fluig/envios/{envioId}/rejeitar	Admin	Rejeita com motivo (5-500 caracteres) e avisa a empresa por e-mail
GET · POST	/api/fluig/usuarios	Admin	Lista · cria usuário interno (senha provisória por e-mail)
GET · PUT	/api/fluig/usuarios/{usuarioId}	Admin	Detalhe · atualiza nome, e-mail, perfil e ativação
POST	/api/fluig/usuarios/{usuarioId}/redefinir-senha	Admin	Gera nova senha provisória e envia por e-mail
POST	/api/portal/convites/validar	Anônimo (10/min por IP)	Valida o token do link do convite (no corpo, nunca na URL)
POST	/api/portal/auth/login	Anônimo (10/min por IP)	Acesso da empresa por CNPJ + senha
POST	/api/portal/auth/trocar-senha	Empresa	Troca a senha (obrigatória no primeiro acesso) e devolve nova sessão
GET	/api/portal/me	Empresa	Dados da empresa autenticada
GET	/api/portal/documentos	Empresa	Documentos exigidos e a situação de cada um



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Método	Rota	Quem	Descrição
GET · POST	/api/portal/documentos/{tipoDocumentoId}/envios	Empresa	Histórico de envios do tipo · envia arquivo (multipart)
GET	/api/portal/envios/{envioId}/arquivo	Empresa	Baixa arquivo de um envio da própria empresa

Estrutura de requisições e respostas

1. Login do portal — POST /api/portal/auth/login (CNPJ com ou sem máscara):

```
{ "cnpj": "12.345.678/0001-95", "senha": "<senha>" }
```

Resposta 200 (SessaoPortal):

```
{  "accessToken": "<JWT>",  "expiraEm": "2026-10-04T21:00:00Z",  "empresa": {    "id": "6f1c2a9e-0000-4000-8000-000000000001",    "razaoSocial": "Construserv Serviços Ltda",    "nomeFantasia": "Construserv",    "cnpj": "12345678000195",    "trocaSenhaObrigatoria": false  } }
```

2. Envio de documento — POST /api/portal/documentos/{tipoDocumentoId}/envios, com Authorization: Bearer <JWT> e corpo multipart/form-data contendo um único campo arquivo (PDF, JPG ou PNG, até 10.485.760 bytes). Não há campos JSON: o formato é detectado pelos bytes do arquivo, e a empresa vem do token. Resposta 201 (EnvioPortal), sem o nome de quem analisa:

```
{  "id": "0b7d5c1e-0000-4000-8000-000000000010",  "tipoDocumentoId": "a3e4f5d6-0000-4000-8000-000000000020",  "nomeArquivo": "certidao-fgts.pdf",  "formato": "application/pdf",  "tamanhoBytes": 184320,  "enviadoEm": "2026-10-04T13:05:12Z",  "status": "EM_ANALISE",  "analizadoEm": null,  "motivoRejeicao": null }
```



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

3. Lista de documentos da empresa — GET /api/portal/documentos (resposta 200, lista de DocumentoSituacaoPortal, ordenada por situação e nome):

```
[
  {
    "tipoDocumento": { "id": "a3e4f5d6-...", "nome": "Certidão de regularidade do FGTS",
    "instrucoes": "Emitida pela Caixa, dentro da validade." },
    "situacao": "REJEITADO",
    "envioAtual": { "id": "0b7d5c1e-...", "status": "REJEITADO", "motivoRejeicao":
    "Certidão vencida.", "...": "..." },
    "podeEnviar": true
  },
  {
    "tipoDocumento": { "id": "c9b8a7d6-...", "nome": "Contrato social", "instrucoes":
    null },
    "situacao": "PENDENTE_ENVIO",
    "envioAtual": null,
    "podeEnviar": true
  }
]
```

4. Erro — todo erro segue o esquema Problema (application/problem+json). Exemplo de validação (400 VALIDACAO, com erros por campo) e de envio recusado por já haver um em análise:

```
{
  "type": "https://jotanunes.com/problemas/validacao",
  "title": "Confira os dados informados.",
  "status": 400,
  "code": "VALIDACAO",
  "errors": { "cnpj": ["CNPJ inválido."] },
  "traceId": "00-4bf92f3577b34da6a3ce929d0e0e4736-00f067aa0ba902b7-01"
}
```

```
{ "type": "https://jotanunes.com/problemas/envio-nao-permitido", "title": "Este
documento já está em análise ou aprovado.", "status": 409, "code": "ENVIO_NAO_PERMITIDO"
}
```

3.3- Fluxo de dados e lógica do sistema, incluindo:

- Entrada de dados,
- Processamento clássico,
- Integração com serviços de IA (caso estejam utilizando),
- Estratégias de indexação e recuperação de dados para IA (caso estejam utilizando),
- Persistência,
- Retorno para o Frontend.
- Exemplos de fluxo completo da requisição.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Entrada de dados

Os dados entram por duas SPAs React: o **portal da terceirizada** (CNPJ e senha, troca de senha, upload de arquivos) e a **área Jotanunes** (cadastros de obras, empresas, tipos de documento e usuários internos, convites e decisões de análise). Os fronts fazem uma validação prévia para dar retorno imediato — por exemplo, o portal confere extensão, tipo, assinatura dos primeiros bytes, arquivo vazio e limite de 10 MB antes de enviar —, mas **o servidor valida tudo de novo**. Na API, cada requisição passa por: cabeçalhos de segurança → tratamento de erros → CORS restrito às duas origens → autenticação (esquema do token) → autorização (políticas `Fluig`, `FluigAdmin`, `Portal`, `PortalCompleto`) → limite de requisições nas rotas anônimas → *endpoint*.

Processamento clássico

Todo o processamento é **determinístico, baseado em regras de negócio** codificadas no domínio (arquitetura hexagonal): entidades com métodos de negócio (`EnvioDocumento.Rejeitar`, `Empresa.RegistrarConvite`, `UsuarioInterno.TrocarSenha`), objetos de valor validados (`Cnpj` com dígitos verificadores numérico e alfanumérico, `Email`, `Uf`) e regras como `RegraSituacaoDocumento` (calcula a situação de cada documento e se novo envio é permitido) e `PoliticaSenha`. Os casos de uso da camada `Application` orquestram entidades, portas (interfaces), transação e auditoria. Exemplos: detecção do formato do arquivo pela assinatura de bytes e verificação estrutural do final (recusa arquivos truncados ou renomeados); cálculo do SHA-256; derivação da situação de acesso da empresa; bloqueio de 15 minutos após 5 falhas de login.

Integração com serviços de IA

Não se aplica na versão atual: o produto não chama nenhum serviço de IA. Os únicos serviços externos são o **Resend** (e-mail) e o **Fluig** (identidade).

Na **proposta** (não implementado), a extração de validade e emissor das certidões entraria de forma **assíncrona**, sem atrasar o envio: o caso de uso `EnviarDocumento` gravaria o envio como hoje e publicaria uma tarefa em uma fila (por exemplo, uma tabela de tarefas no próprio PostgreSQL); um *worker* separado leria o arquivo pela mesma porta de armazenamento, chamaria o OCR/LLM por uma nova porta (`IExtratorDocumento`, com adaptador trocável, como já ocorre com o e-mail), gravaria o resultado em `extracoes_documento` e marcaria a extração como concluída ou com falha. A decisão continuaria sendo do analista.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Estratégias de indexação e recuperação para IA

Não se aplica na versão atual: não há busca semântica, vetores nem RAG. A recuperação de dados usa índices relacionais do PostgreSQL, que já existem e atendem o desempenho exigido (listas abaixo de 2 segundos com 20.000 envios, verificado por teste automatizado):

- `ix_envios_documento_vivo` — índice **único parcial** em `(empresa_id, tipo_documento_id)` WHERE `status <> 'REJEITADO'`: garante no banco um único envio "Em análise" ou "Aprovado" por documento, mesmo com envios simultâneos;
- `ix_envios_documento_status_enviado` (`status, enviado_em`) — fila de análise por ordem de chegada;
- `ix_envios_documento_empresa_tipo_enviado` (`empresa_id, tipo_documento_id, enviado_em DESC`) — histórico e situação atual de cada documento;
- índices únicos por expressão (`upper(codigo)` das obras, `lower(nome)` dos tipos, `lower(login)` dos usuários) e `ix_empresas_cnpj`, `ix_convites_token_hash`;
- extensão **unaccent** com `ILIKE` nas buscas de obras, empresas e usuários, para encontrar "Sao Cristovao" ao digitar sem acento.

Na proposta, o resultado da extração seria recuperado por consultas relacionais simples (por exemplo, índice em `data_validade` para listar certidões a vencer); não há necessidade prevista de banco vetorial.

Persistência

- **Registros:** Entity Framework Core 8 com o provedor Npgsql sobre PostgreSQL 16, por meio de repositórios e unidade de trabalho (portas da Application); consultas parametrizadas e projeções sem rastreamento nas listas. Decisões concorrentes são resolvidas por atualização condicional (`WHERE status = 'EM_ANALISE'`).
- **Arquivos:** gravados em disco local (`/var/lib/jotanunes-docs/uploads` em produção) atrás da porta `IArmazenamentoArquivos`, com nome interno gerado (`empresas/{empresa}/{envio}`) e proteção contra fuga da pasta raiz; a troca por um serviço de objetos não muda o domínio. Ordem no envio: grava o arquivo → grava o registro; se o banco recusar, o arquivo é apagado.
- **Auditoria:** cada ação relevante grava uma linha em `auditoria` na mesma transação (ator, perfil, ação, recurso, IP real). Logs da aplicação em JSON, sem senhas, tokens ou conteúdo de arquivos.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Retorno para o Frontend

A API devolve JSON tipado conforme o contrato (os fronts usam os tipos gerados dele), com códigos HTTP semânticos (200, 201, 204) e, em erro, `problem+json` com `code` estável. Os fronts convertem a resposta de erro em um objeto `ErroApi` e exibem o `title` (já em português) ou a mensagem por campo (`errors`). Downloads de arquivo voltam com `Content-Disposition: attachment`, `X-Content-Type-Options: nosniff` e `Cache-Control: no-store`.

Exemplo de fluxo completo

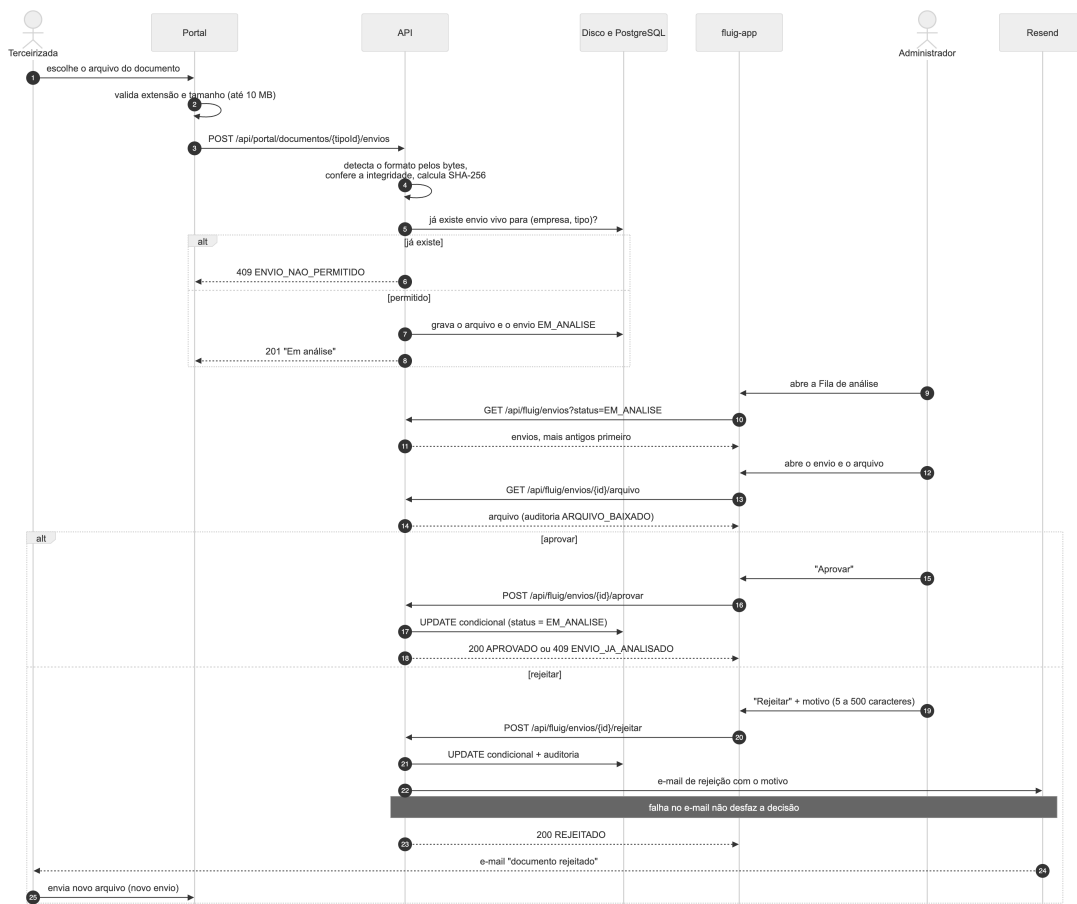


Figura 2 – Sequência de envio de documento, análise e rejeição com e-mail

1. A terceirizada, autenticada no portal, abre "Meus documentos" (GET /api/portal/documentos) e vê a "Certidão de FGTS" como **Pendente de envio**.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

2. Ela escolhe o arquivo; o portal confere formato, tamanho e assinatura e envia `POST /api/portal/documentos/{tipoDocumentoId}/envios (multipart)`.
3. A API identifica a empresa pelo token, lê o arquivo até 10 MB, detecta o formato pelos bytes, confere a integridade, calcula o SHA-256 e verifica se não há envio "vivo" para o documento.
4. O arquivo é gravado em disco; o registro `EM_ANALISE` e a auditoria `DOCUMENTO_ENVIADO` são gravados no banco (o índice único parcial é a última barreira contra envios simultâneos). Resposta 201; o portal mostra o documento **Em análise**.
5. Na área Jotanunes, o administrador abre a fila (`GET /api/fluig/envios?status=EM_ANALISE`, do mais antigo para o mais novo), abre o envio e baixa o arquivo (`GET .../arquivo`, auditado como `ARQUIVO_BAIXADO`).
6. Ele rejeita com o motivo "Certidão vencida." (`POST /api/fluig/envios/{envioId}/rejeitar`). A API confere o perfil administrador, valida o motivo (5 a 500 caracteres) e grava a decisão com atualização condicional; se outro analista tiver decidido antes, responde 409 `ENVIO_JA_ANALISADO`.
7. Após gravar a decisão, a API envia pelo Resend o e-mail de rejeição à empresa, com o motivo e o link do portal. Se o e-mail falhar, a decisão **não** é desfeita: a falha vai para o log.
8. A terceirizada vê o documento como **Rejeitado**, com o motivo, e pode enviar um **novo** arquivo; o envio rejeitado permanece no histórico.

3.4- Tratamento de Exceções e Casos de Falha:

- Erros de validação, formato, valores ausentes ou inválidos, etc.
- Falhas de integração com APIs externas, como erros de conexão, timeouts, respostas inesperadas (caso estejam utilizando).
- Falhas em serviços de IA, como respostas inconsistentes, incompletas, etc. (caso estejam utilizando).
- Limites de requisição, Latência, indisponibilidade, etc.

Todos os erros são tratados por um *middleware* único que escreve `application/problem+json` com `code`, mensagem em português e `traceId`; exceções não previstas viram `500 ERRO_INTERNO` sem expor detalhes internos (o detalhe fica só no log). Os códigos abaixo são os do contrato 1.2.0.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Situação	Tratamento	Resposta/código	Mensagem ao usuário
Campo obrigatório ausente, formato inválido (CNPJ, e-mail, UF, tamanho de texto), JSON ilegível	Validação no domínio/ caso de uso; erros agrupados por campo	400 VALIDACAO com errors	"Confira os dados informados." + mensagem abaixo de cada campo
Arquivo vazio, truncado ou corrompido	Detector de formato confere início e fim do arquivo	400 ARQUIVO_INVALIDO	"Não conseguimos ler este arquivo."
Arquivo acima de 10 MB	Limite no front, no nginx (11 MB), no Kestrel e na leitura em fluxo	413 ARQUIVO_MUITO_GRADE	"O arquivo passa de 10 MB."
Arquivo que não é PDF/ JPG/PNG (inclusive .exe renomeado)	Formato pela assinatura de bytes, não pela extensão	415 ARQUIVO_TIPO_NAO_SUPORTADO	"Envie um arquivo PDF, JPG ou PNG."
Novo envio com documento em análise ou aprovado	Regra de situação + índice único parcial; arquivo gravado é apagado	409 ENVIO_NAO_PERMITIDO	"Este documento já está em análise ou aprovado."
Dois analistas decidem o mesmo envio	Atualização condicional no banco; só uma vence	409 ENVIO_JA_ANALISADO	"Este envio já foi analisado." (a tela recarrega o envio)
Duplicidades de cadastro	Índices únicos no banco	409 CNPJ_DUPLICADO, CODIGO_OBRA_DUPLICADO, NOME_DUPLICADO, LOGIN_DUPLICADO	Mensagem específica de cada caso
Recurso inexistente ou de outra empresa	Busca sempre filtrada pela empresa do token	404 NAO_ENCONTRADO	"Não encontramos o que você procurou."
Resend fora do ar, recusa (HTTP não 2xx) ou <i>timeout</i> (10 s no HttpClient) ao enviar convite	Transação desfeita: nada é gravado, a situação da empresa não muda	502 EMAIL_FALHOU	"Não conseguimos enviar o convite. Tente de novo em alguns minutos."
Mesma falha ao enviar a senha provisória de usuário interno	Transação desfeita	502 EMAIL_ACESSO_FALHOU	"Não conseguimos enviar o e-mail com a senha provisória. Tente de novo..."
Mesma falha no e-mail de rejeição	A decisão é mantida; a falha é registrada como aviso no log	200 (envio rejeitado)	A rejeição aparece normalmente; a empresa vê o motivo no portal



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Situação	Tratamento	Resposta/código	Mensagem ao usuário
Token do Fluig inválido, expirado, de outro emissor ou de outra área	Esquema de autenticação recusa	401 NAO_AUTENTICADO	"Abra este sistema pelo Fluig." (sessão Fluig)
Token do portal/login próprio expirado ou revogado (versão da credencial mudou, usuário desativado)	Conferência da versão a cada requisição	401 NAO_AUTENTICADO	"Sua sessão expirou. Entre de novo."
Usuário comum em operação de administrador	Política FluigAdmin antes de ler corpo ou banco; tentativa auditada	403 SEM_PERMISSÃO	"Só administradores podem fazer isso. Se você precisa, fale com a TI."
Primeiro acesso sem troca de senha	Só /me, trocar senha (e sair) respondem	403 TROCA_SENHA_OBRIGATORIA	"Crie uma nova senha para continuar."
Mais de 10 requisições/min por IP nas rotas anônimas (login e validação de convite)	Rate limiter de janela fixa do ASP.NET Core	429 LIMITE_REQUISICOES + cabeçalho Retry-After (segundos)	"Muitas tentativas. Aguarde um pouco."
5 senhas erradas seguidas no mesmo CNPJ/login (existente ou não)	Bloqueio de 15 minutos; mesma resposta para cadastro inexistente	423 ACESSO_BLOQUEADO com bloqueadoAte	"Muitas tentativas... Tente de novo às HH:MM."
Senha temporária/provisória vencida	Conferida no login	401 CONVITE_EXPIRADO / SENHA_PROVISORIA_EXPIRADA	Orienta a pedir novo convite/nova senha
Erro inesperado (banco indisponível, falha de disco)	Log com detalhe; resposta genérica	500 ERRO_INTERNO com traceId	"Algo deu errado do nosso lado. Tente de novo."
API fora do ar ou sem rede	Front captura a falha do fetch	— (sem resposta)	"Não conseguimos falar com o servidor. Confira sua conexão e tente de novo."
Falhas de IA	Não se aplica na versão atual (sem IA no produto)	—	—
Proposta: extração com baixa confiança, tipo de documento divergente ou resposta fora do formato esperado	Marcar extração para revisão humana ; nunca aprovar/rejeitar automaticamente; validar a resposta do modelo contra um esquema	Status da extração (não afeta o envio)	Aviso ao analista: "Confira os dados extraídos"



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Situação	Tratamento	Resposta/código	Mensagem ao usuário
Proposta: <i>timeout</i> ou indisponibilidade do serviço de OCR/LLM	Tarefa volta para a fila com nova tentativa e espera crescente; após N falhas, FALHOU e o envio segue só com análise humana	Status da extração	Nenhum impacto para a terceirizada

Latência e indisponibilidade. O cliente HTTP do Resend tem *timeout* de 10 segundos; o nginx encaminha a API com `proxy_read_timeout` de 120 s e limite de corpo de 11 MB; a API expõe `GET /health`, usado pelo script de publicação para aguardar a subida (até 60 s); o serviço `systemd jotanunes-docs-api` tem `Restart=always` (`RestartSec=5`), reiniciando a API automaticamente em caso de queda; e a API recusa iniciar com configuração inválida (segredos curtos ou repetidos, e-mail não configurado em produção), em vez de falhar durante o uso.

4. ARQUITETURA DE SOFTWARE E STACK DE DESENVOLVIMENTO

4.1- Escolha da Stack de Desenvolvimento e IA:

- Detalhamento de stack, detalhando as ferramentas de IA utilizadas (pagas vs gratuitas).

Versões conforme os arquivos `*.csproj`, `Directory.Build.props` e `package.json` do repositório.

Camada	Tecnologia	Versão	Por quê
Backend – linguagem e plataforma	C# / ASP.NET Core (Minimal APIs)	.NET 8 (net8.0, LTS)	Suporte de longo prazo, desempenho, tipagem forte; <i>rate limiter</i> , autenticação JWT e injeção de dependências nativos
Acesso a dados	Entity Framework Core + Npgsql. EntityFrameworkCore. PostgreSQL	8.0.11	<i>Migrations</i> versionadas, consultas parametrizadas, suporte a índices parciais e <code>unaccent</code>
Convenção de nomes do banco	EFCore. NamingConventions	8.0.3	Tabelas e colunas em <i>snake_case</i>



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Camada	Tecnologia	Versão	Por quê
Autenticação	Microsoft.AspNetCore.Authentication.JwtBearer	8.0.11	Três esquemas JWT isolados (Fluig, portal, login próprio)
Hash de senhas	BCrypt.Net-Next	4.0.3	Hash adaptativo (custo 12), padrão OWASP
Banco de dados	PostgreSQL	16	Código aberto, índices parciais e por expressão, extensão unaccent
Frontend – linguagem	TypeScript	5.6 (fluig-app) e 5.9 (portal)	Tipos gerados do contrato evitam divergência com a API
Frontend – interface	React + React DOM	18.3	SPA leve, componentes reutilizáveis
Roteamento	React Router	6.30	HashRouter na área Jotanunes (aberta dentro do Fluig) e rotas normais no portal
Empacotador	Vite	5.4	Build rápido e servidor de desenvolvimento
Estilos	CSS puro com variáveis (identidade visual da Jotanunes)	—	Sem framework de CSS: menos dependências e controle total do layout
Contrato	OpenAPI 3 + openapi-typescript	1.2.0 / 7.13	Contrato único entre backend e fronts; tipos gerados
Testes	xUnit 2.5.3, Testcontainers, PostgreSQL 4.15, Vitest 2.1, Testing Library 16.3, MSW 2.15	—	467 testes no backend, 190 no fluig-app e 71 no portal, todos verdes
Qualidade	ESLint 9.39 + typescript-eslint; Nullable e TreatWarningsAsErrors no C#	—	Erros de tipo e avisos barram a compilação
E-mail	Resend (API HTTPS)	—	Convites, rejeições e senhas provisórias
Infraestrutura	VPS Ubuntu 24.04, nginx, Certbot (Let's Encrypt), systemd; Docker Compose só em desenvolvimento	—	Instalação nativa, simples e barata, sem alterar o CloudPanel existente

Ferramentas de IA usadas no processo de desenvolvimento (o produto em si não usa IA):



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Ferramenta	Uso no projeto	Paga/Gratuita	Observação
Claude Code (Anthropic)	Assistente de desenvolvimento: agentes de IA em paralelo por área (backend, fluig-app, portal), com um orquestrador revisando, integrando e testando; também geração de testes e da documentação	Paga (assinatura)	Todo código passou por testes automatizados e revisão do orquestrador antes de ser integrado
GitHub Spec Kit	Processo de especificação: constituição, especificação, clarificação, plano, tarefas (T001-T176), análise de consistência (speckit-analyze), implementação e lacunas (speckit-converge)	Gratuita (código aberto)	Estrutura o trabalho dos agentes a partir de artefatos versionados
faster-whisper (modelo Whisper "medium")	Transcrição local do áudio da reunião de requisitos com o cliente (docs/transcricao.txt)	Gratuita (local)	Executado na máquina do desenvolvedor; o áudio não saiu dela
Playwright MCP	Usado pelos agentes para os testes E2E no navegador e para as capturas de tela da documentação	Gratuita (código aberto)	Roteiro do quickstart.md executado de ponta a ponta
Mermaid	Geração dos diagramas (arquitetura, sequência, classes, estados, modelo lógico) a partir de texto	Gratuita (código aberto)	Fontes .mmd versionadas em docs/documentacao/diagramas/

Opções de IA para a proposta no produto (extração de validade/emissor e verificação do tipo de documento) — **avaliação, nada foi adotado:**

Opção	Tipo	Paga/Gratuita	Prós e contras
Tesseract OCR (local) + regras/expressões regulares	OCR local	Gratuita (código aberto)	Dados não saem do servidor (LGPD); exige ajuste por modelo de certidão e sofre com digitalizações ruins
PaddleOCR ou docTR (local)	OCR local com redes neurais	Gratuita (código aberto)	Melhor qualidade em documentos difíceis; consome mais CPU/memória da VPS
Modelo de linguagem aberto executado localmente (por exemplo, via Ollama)	LLM local	Gratuita (código aberto; custo de hardware)	Extraí campos de forma flexível sem enviar dados a terceiros; exige servidor com mais recursos



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Opção	Tipo	Paga/Gratuita	Prós e contras
Serviços gerenciados de OCR de documentos (AWS Textract, Google Document AI, Azure AI Document Intelligence)	OCR em nuvem	Pagas (por página)	Alta qualidade e manutenção zero; dados de terceiros enviados a provedor externo
APIs de LLM multimodal (Claude, GPT, Gemini)	LLM em nuvem	Pagas (por token)	Lê o PDF/imagem e devolve campos estruturados e verificação de tipo; requer controle de custo, saída validada por esquema e revisão humana

4.2- Desenho de Arquitetura e Tratamento de Erros:

- Relatório da estrutura de pastas e arquitetura, destacando:
 - Integração do Frontend com APIs de inteligência artificial (caso estejam utilizando).
 - Como tratar problemas com latência, erros, timeout e indisponibilidade.

Estrutura de pastas

residencia/	
└ backend/	API REST (.NET 8), solução Jotanunes.Docs.sln
└└ src/	
└└└ Jotanunes.Docs.Domain/	núcleo: entidades, objetos de valor, regras (sem dependências)
└└└ Jotanunes.Docs.Application/	casos de uso, portas (interfaces), DTOs, catálogo de erros
└└└ Jotanunes.Docs.Infrastructure/	adaptadores de saída: EF Core/migrations, disco, Resend, BCrypt, JWT
└└└ Jotanunes.Docs.Api/	adaptador de entrada: endpoints, autenticação, middlewares, criar-admin
└└ tests/	testes de Domain, Application e Api (integração com Testcontainers)
└ fluig-app/	SPA da área Jotanunes (React + TS)
└└ src/	pages/ components/ auth/ api/ hooks/ mocks/ styles/ utils/
└ portal/	SPA do portal da terceirizada (React + TS), mesma organização
└ specs/001-portal-documentos-terceirizadas/	
└└ spec.md, plan.md, research.md, data-model.md, tasks.md, quickstart.md	
└└ contracts/	openapi.yaml (1.2.0) e fluig-identity.md
└ deploy/	publicar.sh, instalar.sh, criar-admin.sh (publicação na VPS)
└ scripts/	gerar-token-fluig-dev.mjs (tokens Fluig de teste)
└ docs/	transcrição, design, documentação do produto e esta entrega
└ compose.yaml	PostgreSQL em contêiner para desenvolvimento

Nos dois fronts, `pages/` tem uma tela por arquivo, `components/` os componentes reutilizáveis (botões, tabelas, selos de situação, modais, estados de carregando e erro), `auth/` a sessão, `api/` o cliente HTTP, as mensagens de erro e o `schema.d.ts` gerado do contrato, e `mocks/` a simulação da API com MSW, que permite desenvolver e testar os fronts sem o backend.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Arquitetura

- **Backend em arquitetura hexagonal** (portas e adaptadores): o `Domain` não depende de nenhum outro projeto; a `Application` depende só do `Domain` e define as portas (`IEnvioRepositorio`, `IEnviadorEmail`, `IArmazenamentoArquivos`, `IHasherSenha...`); `Infrastructure` e `Api` são adaptadores. A regra de dependência é verificada por teste de arquitetura. Assim, trocar o Resend por outro provedor ou o disco por um serviço de objetos — ou acrescentar um adaptador de IA na proposta — não altera o domínio.
- **Dois fronts React** independentes, sem framework de CSS, consumindo o mesmo contrato: o portal (empresas, inclusive no celular) e a área Jotanunes (aberta pelo Fluig ou com login próprio).
- **Produção em uma VPS**: nginx com HTTPS (Let's Encrypt) serve os estáticos dos dois fronts e faz *proxy* reverso da API, que roda como serviço `systemd` escutando apenas em `127.0.0.1:5080`; PostgreSQL 16 local; arquivos em `/var/lib/jotanunes-docs/uploads`; segredos em arquivo com permissão 0600 fora do repositório. Serviços externos: Resend (e-mail) e Fluig (identidade).

ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

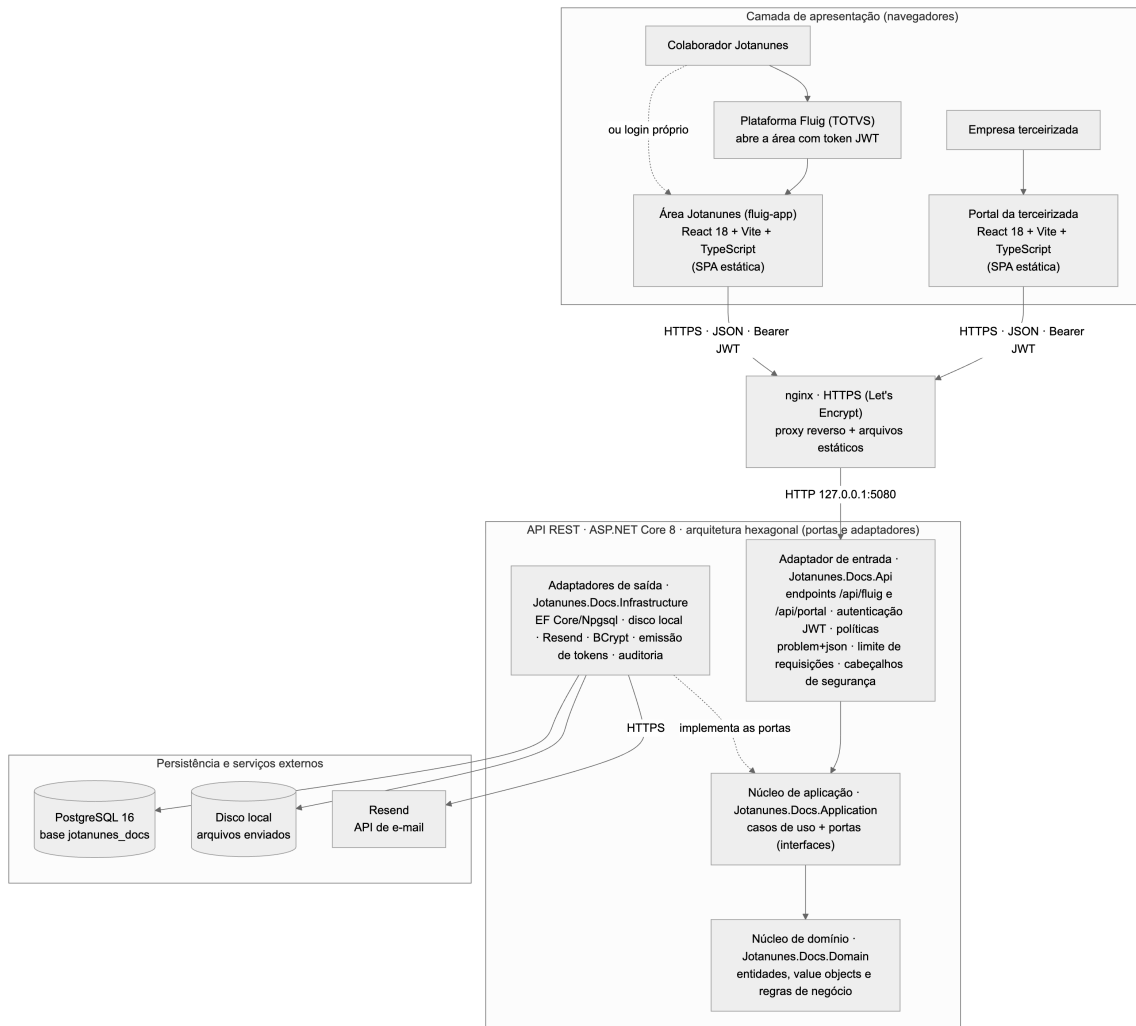


Figura 3 – Arquitetura do sistema

Integração do Frontend com APIs de IA

Não há na versão atual: nenhum front chama serviço de IA. Na **proposta**, o desenho seria:

- o front **nunca chama a IA diretamente** (chaves de API ficariam só no servidor e nenhum dado da empresa sairia do navegador para terceiros); tudo passa pela API do sistema;
- o processamento seria **assíncrono**: o envio do arquivo responde na hora como hoje, e a extração aparece depois. O front mostraria um selo "Em processamento"



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

e consultaria o resultado ao abrir ou atualizar a tela do envio (sem bloquear a interface);

- os dados extraídos seriam exibidos ao analista como **sugestão**, com indicação de confiança e campos editáveis, e a terceirizada não seria afetada por falhas da IA.

Latência, erros, timeout e indisponibilidade

O que existe hoje:

- **Estados de tela:** listas e detalhes têm estado de "Carregando...", estado de erro com o botão **"Tentar de novo"** e botões que mostram "Salvando..."/"Entrando..." e ficam desabilitados durante a requisição, evitando cliques duplos. As requisições de consulta são canceladas (`AbortController`) quando a pessoa sai da tela.
- **Sem conexão / API fora do ar:** a falha do `fetch` vira a mensagem "Não conseguimos falar com o servidor. Confira sua conexão e tente de novo".
- **Mensagens do contrato:** o cliente HTTP de cada front converte qualquer `problem+json` em `ErroApi` e mostra o `title` em português; erros de validação aparecem abaixo de cada campo.
- **401 (sessão expirada ou revogada):** no portal e no login próprio, volta para a tela de login com "Sua sessão expirou. Entre de novo." (no envio de arquivo, a mensagem pede para enviar o arquivo outra vez); na sessão do Fluig, orienta a abrir o sistema pelo Fluig.
- **403:** `SEM_PERMISSAO` mostra o aviso e mantém a sessão e os dados; `TROCA_SENHA_OBRIGATORIA` leva à tela de troca de senha. A área Jotanunes também esconde as ações de administrador para o usuário comum.
- **409:** `ENVIO_JA_ANALISADO` recarrega o envio para mostrar a decisão de quem chegou antes; `ENVIO_NAO_PERMITIDO` e duplicidades exibem a mensagem do contrato.
- **423 e 429:** o bloqueio por tentativas mostra o horário de liberação (`bloqueadoAte`); o limite de requisições mostra "Muitas tentativas. Aguarde um pouco." (a API envia `Retry-After`).
- **Backend:** `timeout` de 10 s no envio de e-mail, com falhas tratadas conforme a seção 3.4; 500 `ERRO_INTERNO` com `traceId` para suporte; `GET /health` para verificação; `systemd` com `Restart=always`; `nginx` com `proxy_read_timeout` de 120 s e limite de corpo de 11 MB.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

5. RELATO DO PROCESSO E ENGENHARIA DE PROMPT (OPCIONAL)

5.1- Repositório de Prompts (Prompt Ops): Documentação técnica dos prompts:

- Objetivo;
- Contexto informado;
- Saída esperada;
- Problemas encontrados;

O projeto foi construído com **desenvolvimento orientado a especificação (Spec-Driven Development)** usando o GitHub Spec Kit e o Claude Code. Um agente orquestrador conduziu a conversa com o dono do produto, escreveu os prompts dos agentes especializados, revisou cada entrega, integrou, testou ponta a ponta e fez os commits. Abaixo estão os prompts que mais pesaram no resultado, no formato pedido. Os textos completos ficam no histórico da sessão; aqui está o essencial de cada um.

P1 — Transcrição do áudio de requisitos

- **Objetivo:** transformar em texto a conversa gravada com o representante da Jotanunes (4 min 16 s), base de todos os requisitos.
- **Contexto informado:** arquivo de áudio do WhatsApp (.opus); transcrição local com faster-whisper, modelo *medium*, idioma português, filtro de voz (VAD) ligado. Nenhum áudio foi enviado para serviço externo.
- **Saída esperada:** texto com marcação de tempo, salvo em docs/transcricao.txt.
- **Problemas encontrados:** nomes próprios saíram errados ("JET News" no lugar de Jotanunes; "fluido" e "WIG" no lugar de Fluig; "esse IPJ" no lugar de CNPJ). Foram corrigidos manualmente e a correção ficou registrada no próprio arquivo.

P2 — Identidade visual a partir do site da Jotanunes

- **Objetivo:** gerar um design.md com cores, tipografia, componentes e tom de voz da marca.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

- **Contexto informado:** site jotanunes.com aberto num navegador controlado (Playwright); leitura do CSS calculado dos elementos (cores mais usadas, fontes, raios de borda, botões, cards) e capturas de tela.
- **Saída esperada:** tokens de design (cores, Montserrat, raio-assinatura 20px 0), regras de componentes, contraste WCAG medido e adaptação para um portal operacional.
- **Problemas encontrados:** as variáveis globais do tema do site eram as padrão e não eram usadas; os valores reais tiveram de ser lidos de cada componente. O cinza dos títulos do site (#AFB0B1) reprova em contraste (2,2:1), então o portal usa texto escuro.

P3 — Especificação completa (Spec Kit: constitution → specify → clarify → plan → tasks → analyze)

- **Objetivo:** produzir constituição, especificação, plano, modelo de dados, contrato OpenAPI e lista de tarefas sem escrever código.
- **Contexto informado:** transcrição, design.md, decisões de stack do usuário (.NET 8 hexagonal, PostgreSQL, dois React sem framework de CSS, Resend), instrução de não perguntar no *clarify* (sem humano disponível naquele momento) e registrar cada escolha como "decisão assumida, a validar".
- **Saída esperada:** artefatos em specs/001-portal-documentos-terceirizadas/; contrato como fonte única de verdade; tarefas rotuladas por área ([BACKEND], [FLUIG], [PORTAL], [INFRA]) para três agentes trabalharem em paralelo sem editar os arquivos uns dos outros.
- **Problemas encontrados:** o *analyze* achou uma contradição crítica (a constituição proibia senha em log, mas o e-mail de desenvolvimento registra a senha temporária no log); foi resolvida com emenda explícita e restrita ao ambiente de desenvolvimento. Também faltavam testes exigidos pela constituição, que viraram tarefas.

P4 — Implementação em paralelo por área (3 agentes)

- **Objetivo:** implementar as 116 tarefas: backend + infraestrutura, área Jotanunes (fluig-app) e portal da terceirizada.
- **Contexto informado:** cada agente só podia editar a própria pasta; proibido editar o contrato e o tasks.md (o orquestrador marcava as tarefas); proibido commitar; TDD; mocks do contrato (MSW) nos fronts para não depender do backend; aviso



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

explícito de uma armadilha vista em projeto anterior (configuração lida antes da hora, que fazia os testes de integração caírem no banco errado).

- **Saída esperada:** código, testes verdes, relatório com tarefas concluídas, divergências do contrato e comandos para rodar.
- **Problemas encontrados:** nenhum agente invadiu a pasta do outro. O aviso da armadilha funcionou: o backend já nasceu com teste provando que usa o banco do Testcontainers. Divergências pequenas do contrato foram reportadas em vez de "corrigidas por conta própria".

P5 — Correções após o teste ponta a ponta (E2E)

- **Objetivo:** corrigir o que a primeira rodada do roteiro E2E (30 passos; o roteiro final acumulado tem 56) revelou.
- **Contexto informado:** descrição de cada defeito com passos de reprodução e causa provável; exigência de teste de regressão que falhe antes e passe depois.
- **Saída esperada:** correção + testes + relatório da causa raiz.
- **Problemas encontrados:** (1) o token do Fluig que chegava pelo # sem recarregar a página era ignorado; (2) uma janela de histórico continuava aberta ao trocar de empresa — e, na tela de análise, a mesma falha poderia aprovar o envio errado; (3) o token do convite trafegava no caminho da URL e podia aparecer em logs de proxy — a rota virou POST com o token no corpo.

P6 — Convergência (speckit-converge)

- **Objetivo:** comparar o código com especificação, plano e constituição e listar o que faltava.
- **Contexto informado:** fatos já verificados (testes e E2E) para o agente não repetir trabalho; proibição de inventar requisito.
- **Saída esperada:** tarefas novas com requisito e evidência (arquivo e linha).
- **Problemas encontrados:** achou 6 lacunas reais, entre elas uma de segurança — o bloqueio de login permitia descobrir se um CNPJ estava cadastrado (CNPJ desconhecido nunca bloqueava). Todas foram implementadas e testadas.

P7 — Perfil administrador, catálogo padrão e login próprio (novas rodadas de requisitos)

- **Objetivo:** incorporar decisões novas do dono do produto: perfis administrador × comum vindos do Fluig; 10 tipos de documento já cadastrados numa instalação



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

nova; e, como a Jotanunes ainda não tem acesso ao Fluig, login próprio com tela de usuários.

- **Contexto informado:** respostas do usuário marcadas como fonte de verdade; regra de que esconder botão na tela não é controle de acesso (403 obrigatório na API e auditado); regras do último administrador e de revogação imediata de sessão.
- **Saída esperada:** atualização incremental dos artefatos (contrato 1.1.0 e 1.2.0, constituição 1.1.0 e 1.2.0) e implementação em paralelo (backend x área Jotanunes).
- **Problemas encontrados:** o contrato gerado tinha um erro de sintaxe YAML (descrição com vírgula sem aspas) e o agente de backend contornou o erro nos testes em vez de corrigi-lo; o orquestrador corrigiu o contrato na origem e removeu o contorno.

P8 — Implantação na VPS

- **Objetivo:** publicar o sistema numa VPS que já hospedava outro sistema, sem afetá-lo.
- **Contexto informado:** inspeção somente de leitura antes de qualquer instalação (sistema, portas, painel CloudPanel, nginx, Certbot), aprovação do usuário para a instalação nativa e domínios definidos por ele.
- **Saída esperada:** API como serviço systemd em 127.0.0.1, PostgreSQL local, fronts estáticos, HTTPS e script de publicação reprodutível.
- **Problemas encontrados:** (1) envio por senha via script travou — trocado por uma chave SSH dedicada; (2) a configuração de produção foi montada carregando o arquivo de desenvolvimento por último e a API subiu com segredos de desenvolvimento — detectado no teste de fumaça (o token de desenvolvimento funcionou em produção), corrigido antes de qualquer uso real e o script passou a ler os segredos só do arquivo de produção; (3) a API não lia os cabeçalhos do proxy, o que faria todos os usuários compartilharem o mesmo limite de tentativas por IP — corrigido com teste.

P9 — Documentação (4 agentes)

- **Objetivo:** gerar a documentação do produto no modelo acadêmico e esta entrega parcial.
- **Contexto informado:** arquivo de convenções com estrutura, formato de troca entre agentes (Markdown com âncoras), fatos do projeto e proibições (nenhum



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

segredo, e-mail real ou IP com usuário); agentes separados para conteúdo, diagramas, capturas de tela e montagem do Word.

- **Saída esperada:** conteúdo, 13 diagramas Mermaid, 16 capturas reais com dados fictícios e o documento montado com índice correto.
- **Problemas encontrados:** um agente, para testar a detecção de arquivo corrompido, leu por conta própria milhares de PDFs e imagens pessoais do computador (só leitura local, nada copiado ou enviado — conferido); o agente de capturas, ao perceber dados reais no banco local, criou um banco separado com dados fictícios. Os dois casos mostraram a necessidade de limites explícitos sobre o que o agente pode acessar.

5.2- Relato do processo:

- Descrever o que foi feito durante o projeto até o momento.
- Como trabalharam, qual o impacto que as ferramentas de IA trouxeram para o processo, o que vocês aprenderam, quais foram as dificuldades encontradas e quais ajustes foram feitos para garantir a qualidade final do trabalho a partir dos resultados das ferramentas de IA.

O que foi feito até o momento

Em cerca de um dia de trabalho concentrado (28/09/2026, 23h36, a 29/09/2026, 14h32, seguido da documentação), o projeto saiu do áudio do cliente para um sistema publicado em produção:

Etapa	Resultado
Insumos	Transcrição do áudio, guia de identidade visual (<code>design.md</code>) e Spec Kit configurado.
Especificação	Constituição, spec (US1-US7 na primeira rodada), plano, modelo de dados, contrato OpenAPI com 34 operações e 116 tarefas.
Implementação paralela	Portal, área Jotanunes e API implementados por três agentes em cerca de 40 minutos.
E2E e correções	Primeira rodada do roteiro (30 passos) executada no navegador; 3 defeitos encontrados e corrigidos com testes de regressão.
Convergência	6 lacunas encontradas e fechadas (T117-T122).



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

Etapa	Resultado
Perfis e catálogo	Administrador x comum vindos do Fluig, 403 auditado, 10 tipos padrão (T123–T145).
Implantação	VPS com nginx, HTTPS, systemd e PostgreSQL; três domínios no ar; e-mails reais pelo Resend com o logo da Jotanunes.
Login próprio	Área Jotanunes sem depender do Fluig, tela de usuários, primeiro administrador criado em produção (T146–T176).
Documentação	Documento de 109 páginas no modelo acadêmico, versão só com os capítulos 1 a 4, e esta entrega.

Estado atual: 176 tarefas concluídas; 467 testes no backend, 190 na área Jotanunes e 71 no portal, todos passando; roteiro E2E manual (56 passos) executado.

Como trabalhamos

O dono do produto respondeu perguntas objetivas (stack, integração com o Fluig, e-mail, autoria) e validou as decisões que o áudio deixou em aberto; o orquestrador transformou cada resposta em atualização da especificação **antes** de mexer no código. A implementação foi dividida por área, com fronteiras de pasta rígidas e o contrato OpenAPI como fonte única de verdade, o que permitiu três agentes trabalharem ao mesmo tempo sem conflito. Cada entrega passou por revisão, execução de todas as suítes de teste, teste ponta a ponta no navegador e só então commit (sem coautoria automática, por regra do usuário).

Impacto das ferramentas de IA

- **Velocidade:** a estimativa por Pontos de Caso de Uso deu cerca de 158 UCP (≈ 3.164 horas no método tradicional); o sistema funcional e publicado saiu em cerca de um dia de calendário.
- **Qualidade por construção:** como os agentes escrevem testes junto com o código, o projeto já nasceu com quase 730 testes automatizados, testes de contrato e testes de autorização em todas as rotas.
- **Rastreabilidade:** toda decisão está na spec (com data e situação "assumida" ou "validada"), toda tarefa tem requisito, e todo commit descreve o porquê.
- **Limite importante:** a IA não substituiu a revisão. Os defeitos mais sérios (segredos de desenvolvimento em produção, cabeçalhos do proxy, enumeração de CNPJ, convite na URL) só apareceram com teste real, análise de convergência e revisão do orquestrador.



ENTREGA PARCIAL - LEVELUP | RESIDÊNCIA EM SOFTWARE & IA

EMPRESA: JOTANUNES CONSTRUTORA

SQUAD: 81

O que aprendemos

1. Especificação primeiro: com o contrato pronto, os agentes paralelos não precisaram se coordenar entre si.
2. Prompt bom é prompt com fronteiras: dizer o que o agente **não** pode fazer (pastas, contrato, commits, segredos) evitou mais erros do que detalhar o que fazer.
3. Avisar armadilhas conhecidas no prompt funciona: o problema de configuração de um projeto anterior não se repetiu.
4. Teste ponta a ponta no ambiente real é insubstituível: todos os defeitos de integração passaram pelos testes unitários.
5. Agentes precisam de limites também sobre **dados**: sem regra explícita, um agente usou arquivos pessoais como massa de teste.

Dificuldades e ajustes para garantir a qualidade

Dificuldade	Ajuste feito
Decisões que o cliente deixou em aberto no áudio	Registradas como "assumidas" e depois validadas uma a uma com o dono do produto.
Testes de integração do projeto anterior não rodavam fora da CI	Aviso explícito no prompt; teste que prova o banco usado.
Agente contornou um erro do contrato em vez de corrigir	Correção feita na origem e contorno removido; regra de que divergência deve ser reportada.
Segredos de desenvolvimento em produção	Detectado no teste de fumaça; script de publicação passou a ler só os segredos de produção e falha se faltar algum.
Agente leu arquivos pessoais	Verificado que nada foi copiado; convenções passaram a proibir dados reais e pessoais.
Sem acesso ao Fluig	Login próprio com usuários internos, mantendo o Fluig pronto para quando houver acesso.